



University of Piraeus
School of Information and Telecommunications Technologies
Department of Digital Systems
Postgraduate Program “Government Security and Technological
Intelligence”

Information Security Management

Analysis of software methodologies and tools for information security
risk/risk management

Supervising Teachers: K. Lambrinoudakis – S. Grizalis

Kalaitzidis Ioannis

ioannis_kalaitzidis@ssl-unipi.gr

Piraeus
22/12/2025

Abstract

This paper comparatively examines the risk management methodologies of ISO/IEC 27005:2022 and NIST (SP 800-30 rev.1 and SP 800-39), while at the same time evaluating four specialized software tools (SimpleRisk, Monarc, Verinice, EAR/PILAR). Through theoretical analysis, the fundamental differences between ISO's flexible philosophy and NIST's rigorously structured approach are highlighted. At the same time, the practical testing of the applications captures the distance between theoretical standards and operational reality, offering evidence-based conclusions for selecting the optimal solution based on usability, cost, and regulatory requirements.

Contents

1. Introduction.....	5
1.1 Object and Purpose of the Thesis.....	5
1.2 Methodology and Evaluation Criteria.....	5
2. ISO 27005 Methodology Analysis.....	6
2.1 Identity and origin.....	6
2.1.1 Issuing Body and Origin	7
2.1.2 Current Version.....	7
2.1.3 Legal nature	7
2.1.4 Geographical Scope	8
2.1.5 Cost of Access.....	8
2.2 Purpose and architecture	9
2.2.1 Level of focus	9
2.2.2 Relationship with other standards	10
2.2.3 Management cycle	10
2.3 Risk Assessment Methodology	11
2.3.1 Assessment approach	11
2.3.2 Flexibility of methodology	12
2.3.3 Risk calculation technique	13
2.3.4 Lists of threats/vulnerabilities	13
2.4 Resources and Application	14
2.4.1 Complexity of implementation	14
2.4.2 Resources required (implementation costs)	15
3. Analysis of NIST Methodologies (SP 800-30 rev.1 and SP 800-39)	16
3.1 Introduction.....	16
3.2 Identity and origin.....	16
3.2.1 Issuing Body and Origin	17
3.2.2 Current Version.....	17
3.2.3 Legal nature	17

3.2.4 Geographical Scope	18
3.2.5 Access Costs	18
3.3 Purpose and architecture	19
3.3.1 Level of focus	19
3.3.2 Relationship with other standards	20
3.3.3 Management Cycle	21
3.4 Risk Assessment Methodology	21
3.4.1 Assessment approach	21
3.4.2 Flexibility of methodology	22
3.4.3 Risk calculation technique	23
3.4.4 Lists of threats/vulnerabilities	23
3.5 Resources and Application	24
3.5.1 Complexity of implementation	24
3.5.2 Resources required (implementation costs)	25
4. Benchmarking and Conclusions	27
4.1 Summary Table of Criteria	27
4.2 Conclusions of Theoretical Comparison	30
5. Introducing Software Tools	32
5.1 Introduction	32
5.2 Tools	34
5.2.1 SimpleRisk	34
5.2.1.1 Technical Identity and Licensing	34
5.2.1.2 Risk Management Functionality	35
5.2.1.3 User Experience	38
5.2.2 Monarc	39
5.2.2.1 Technical Identity and Licensing	39
5.2.2.2 Risk Management Functionality	40
5.2.2.3 User Experience	44
5.2.3 Verinice	45
5.2.3.1 Technical Identity and Licensing	45
5.2.3.2 Risk Management Functionality	46

5.2.3.3 User Experience	48
5.2.4 EAR/PILAR.....	48
5.2.4.1 Technical Identity and Licensing.....	49
5.2.4.2 Risk Management Functionality	51
5.2.4.3 User Experience	54
5.3 Benchmarking and Conclusions	55
6. Bibliography	58

1. Introduction

1.1 Object and Purpose of the Thesis

The scope of this paper falls within the broader scope of Information Security Risk Management (ISRM), a process vital for ensuring the integrity, confidentiality and availability of data in modern organizations. As cyber threats evolve and the regulatory framework becomes stricter, selecting the appropriate methodology and supporting software tools becomes a critical decision of strategic importance.

The aim of the thesis is the theoretical benchmarking of two of the most recognized methodologies worldwide: the international standard ISO 27005 and the guidelines of the US National Institute of Standards and Technology (NIST), specifically the documents NIST SP 800-30 rev.1 (Guide for Conducting Risk Assessments) and NIST SP 800-39 (Managing Information Security Risk). This comparison is not limited to a superficial comparison, but is based on the development and application of a set of specific criteria relating to structure, methodology of analysis, flexibility and resource requirements. In addition, the thesis aims at the practical evaluation of four software tools (SimpleRisk, Monarc, Verinice, EAR/PILAR) that support the risk management process. Through installation and trial operation (in an open source or trial environment), the extent to which these tools incorporate theoretical methodologies and meet the needs of an organization will be examined, based on a second set of technical and operational criteria.

In summary, the present study aspires to bridge the gap between the theoretical approach to standards and their practical application through digital tools, providing informed conclusions for the selection of the optimal solution.

1.2 Methodology and Evaluation Criteria

For the implementation of the comparative study, a systematic methodological approach was adopted that is divided into two phases, corresponding to the objectives of the work, the theoretical analysis of the standards and the practical evaluation of the tools.

Regarding the first and theoretical part of the work (Comparison of ISO 27005 with NIST SP 800-30 rev.1 and NIST SP 800-39), a specialized evaluation framework was developed. In order for the comparison to be structured and objective, four fundamental thematic axes (criteria) have been defined, which are applied horizontally to both methodologies under consideration:

1. Identity and Origin:

The "administrative" characteristics of the documents, such as the issuing body, their legal nature, their geographical scope and the cost of obtaining and using them, are examined.

2. Purpose and Architecture:

The scope of application and the structural philosophy of each framework are analyzed. In particular, it is investigated whether the methodology follows a unified approach or whether it is divided into levels, as well as how it fits into the management lifecycle.

3. Risk Assessment Methodology:

The technical core of the process is evaluated. The approaches to orientation, the degree of flexibility provided to the organisation and the proposed risk calculation techniques are compared.

4. Resources and Application:

The requirements for the implementation of each standard in terms of human resources, know-how and complexity, as well as the necessary bureaucratic support, are assessed.

2. ISO 27005 Methodology Analysis

2.1 Identity and origin

2.1.1 Issuing Body and Origin

The ISO/IEC 27005 standard is issued jointly by the International Organization for Standardization (ISO) and the International Electrotechnical Commission (IEC), which form the specialized system for global standardization [1]. National bodies that are members of ISO or IEC are involved in the development of International Standards through technical committees established by the respective organization to deal with specific areas of technical activity [2]. In the case of Greece, the national body that is a full member and represents the country in the ISO and IEC organizations is the Hellenic Organization for Standardization (ELOT) [5].

In particular, this document has been prepared by the Joint Technical Committee ISO/IEC JTC 1 (Information Technology) and in particular by Sub-Committee SC 27, which is responsible for information security, cybersecurity and privacy protection [3]. As regards the origin of the current version, this is the fourth version of the standard, which cancels and replaces the third version (ISO 27005:2018) [4].

2.1.2 Current Version

The current international version of the standard, which is the subject of this study, is the fourth edition and was published in October 2022 [6]. It is noted that the standard has been adopted as it is in the Greek standardization as ELOT EN ISO/IEC 27005:2024. This version cancels and replaces the third version (ISO 27005:2018), which has undergone a technical revision [4]. The main changes introduced with the 2022 edition include the full alignment of the guidance text with ISO 27001:2022 and ISO 31000:2018 [7]. In addition, the terminology has been adapted to be in line with that of ISO 31000:2018 [8], while the paragraph structure has been adapted to follow the provision of ISO/IEC 27001:2022 [9]. It is noted that the standard has been adopted as it is in the Greek standardization as ELOT EN ISO/IEC 27005:2024.

2.1.3 Legal nature

In terms of its legal nature, ISO 27005:2022 is an International Standard of voluntary application and not a legal or regulatory provision. In the preface to the document, there is an explicit reference to the voluntary nature of the standards, referring to a specific explanation by the Agency on this subject [10].

The nature of the document is clearly advisory and not mandatory, as it is defined as "Guidance" for information security risk management. Its purpose is to provide guidance to help organizations meet the requirements of ISO 27001 and carry out risk management activities, without penalizing non-implementation [11].

2.1.4 Geographical Scope

As an international standard, ISO 27005 has a global geographical reach and recognition. The standardization system set up by ISO and IEC is specialized for worldwide standardization, ensuring that the standards issued are accepted internationally [12]. The development of the standard is based on the participation of national bodies from all over the world, which take part in the technical committees, thus ensuring representativeness and global consensus [13]. In addition, its scope is not limited geographically or sectorally. The document explicitly states that it is applicable to all organisations, regardless of their type, size or sector of activity, making it suitable for use by multinational enterprises to small local companies in any country [14].

2.1.5 Cost of Access

The ISO/IEC 27005 standard is not freely available, but is a Copyright Protected Document [15]. Its ownership belongs to the issuing organization and access to it is strictly controlled. In the case of Greece, the official cost of purchasing the standard (ELOT EN ISO/IEC 27005:2024) from the Hellenic Organization for Standardization (ELOT) amounts to €95.00, according to the current price list of the organization [16].

In addition to the acquisition cost, the implementation of the standard entails internal costs for the organization, as it requires the commitment of specific resources. According to the document, top management must ensure that the necessary resources are available for risk management [17].

Operating costs depend on three key factors identified in the standard:

1. **Financing and Budgeting:** Risk assessments should take into account business budget cycles and be planned in time to approve the necessary funds [18].
2. **Know-how and Human Resources:** People with the appropriate expertise are required to carry out the tests and analyses [19].
3. **Technology and Tools:** The choice of assessment methods (e.g. vulnerability checks) depends directly on the available funds and available technology [19].

Finally, as part of continuous improvement, the organization is required to monitor the total cost of ownership of the risk management process [20].

2.2 Purpose and architecture

2.2.1 Level of focus

ISO 27005 adopts an organization-run approach, connecting the strategic layer with the operational one. Its scope is broad and can cover the whole of an organisation or specific parts of it (e.g. an IT department), regardless of size or sector of activity [21].

A key feature of his focus is the orientation towards business goals. The very definition of risk in the standard is described as "the effect of uncertainty on goals" [22]. Therefore, the risk management process primarily focuses on decision-making that affects the achievement of the organization's objectives [23].

To bridge the gap between strategy and technology, the standard distinguishes assets into two levels:

1. **Primary/Business Assets:** These refer to the information and business processes that have value to the organization.
2. **Supporting Assets:** These refer to the elements of the information system (Hardware, Software, Networks, Personnel) on which the primary elements are based [24].

Through this structure, the standard focuses on how technical vulnerabilities of supporting components can affect business processes, thus covering both the information system layer and the business process level.

2.2.2 Relationship with other standards

ISO 27005 does not operate autonomously, but is an integral part of the ISO 27000 family of standards. In particular, it is designed to support the implementation of the Information Security Management System (ISMS) specified in the ISO 27001 standard [25].

Its role is complementary and guiding. While ISO 27001 sets out the requirements for risk management, ISO 27005 provides guidance on how to meet these requirements [26]. In addition, the document is complementary to ISO 27003, which concerns the implementation of an ISMS more generally [27].

In a broader context, the standard is fully aligned with ISO 31000, which is the general standard for risk management (regardless of industry). ISO 27005 essentially adapts the general principles of ISO 31000 to the specific information security environment [28]. Finally, for its terminology it is based on the ISO 27000 standard, which provides the vocabulary of the family [29].

2.2.3 Management cycle

The architecture of ISO 27005 is not linear, but is based on an iterative approach [30]. The risk management process is aligned with the general model of ISO 31000 and includes the stages: Framework Definition, Risk Assessment (Identification, Analysis, Assessment), Response, Monitoring and Communication as shown in the diagram below [31].

The standard explicitly distinguishes between two management cycles that must operate in parallel:

1. **Strategic cycle:** This refers to long-term changes in the general context of the organization, where business assets, sources of risk and objectives evolve [32].
2. **Operational cycle:** It concerns shorter periods of time and focuses on reviewing and updating risk scenarios and their response, based on new data or changes in criteria [33].

Finally, the whole process is governed by the principle of Continuous Improvement. The standard requires that the risk management process be continuously

monitored, reviewed, and improved to remain relevant to business objectives [34].

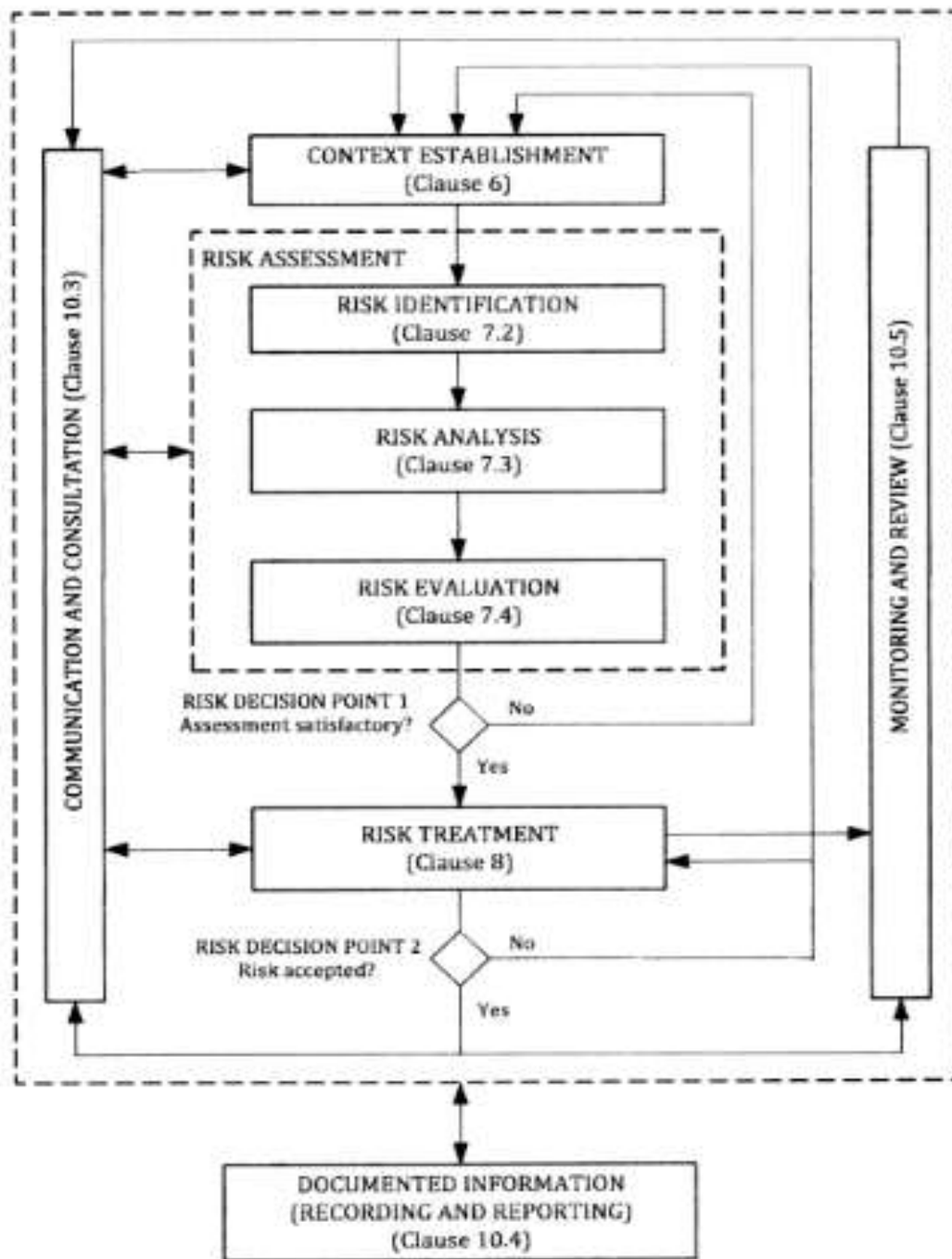


Figure 1 — Information security risk management process

2.3 Risk Assessment Methodology

2.3.1 Assessment approach

ISO 27005 does not impose a single, mandatory method for performing the risk assessment, leaving the organization the freedom to choose the one that suits its needs. A key requirement is that the chosen method ensures that the results of the repeated evaluations are consistent, valid and comparable [35]. However, the standard distinguishes and proposes two main approaches to identifying risks [36]:

- a) **Event-based approach:** This approach focuses on identifying "strategic scenarios". It examines the sources of risk and how they interact with stakeholders to achieve their objectives [37].
 - It is ideal for creating high-level scenarios, without requiring the consumption of significant time to record all assets in detail [38].
 - It is often based on the discovery of top management concerns and allows the organization to focus its response efforts on critical risks [38].
- b) **Asset-based approach:** This is the approach that focuses on identifying "operational scenarios", which are detailed in terms of assets, threats and vulnerabilities [39].
 - It is based on the notion that risk arises from the examination of an asset, where such is defined as anything that has value to the organization and requires protection [40].
 - This method allows for the identification of asset-specific threats and vulnerabilities, leading to the definition of detailed response measures [41].

Relationship between the two approaches: In essence, the two approaches describe the same risk scenario but move in opposite directions. The event-based approach starts at the general level of the scenario and delves into the details to identify the sources of risk (drill down) [42]. In contrast, the asset-based approach starts from the specific asset and investigates upwards towards the scenario, in order to highlight how the individual consequences add up and evolve to ultimately affect the organism [43].

2.3.2 Flexibility of methodology

The methodology of ISO 27005 is characterized by a high degree of flexibility and non-regulatory character. The standard explicitly states that it does not impose a

specific approach or method to meet risk management requirements, allowing the organization to choose or develop the method that best suits its needs [44].

Unlike "prescriptive" standards that define strict mathematical formulas, ISO 27005 serves as a reference framework. It gives the organisation discretion to choose between three types of analytical techniques, depending on maturity and available data [45]:

1. **Qualitative:** Use descriptive scales (e.g., High, Medium, Low).
2. **Quantitative:** Use of numerical values (e.g., monetary cost or probability of occurrence).
3. **Semi-quantitative:** Use of qualitative scales to which values have been assigned.

Although the standard provides samples (Annex A), it explicitly specifies that these are merely examples. The categories and prices presented are not binding [46]. On the contrary, it is stressed that no organisation is likely to be fully covered by the scales of examples and that the framework and scope of the organisation should be used to set realistic boundaries [47].

2.3.3 Risk calculation technique

The level of risk calculation technique in ISO 27005 is not limited to a single algorithm, but can be defined in many possible ways. However, the most common practice described is to define risk as a combination of the estimated probability and the estimated consequences for all relevant scenarios [48]. The standard provides considerable freedom in formulating the mathematical formula or logical relationship:

- **Inclusion of Fixed Asset Value:** Alternative calculations can explicitly include the asset value as a third parameter, along with probability and consistency [49].
- **Non-Linear Calculations:** The relationship between factors is not necessarily linear (e.g. not a simple operation but more complex) [50].

In any case, the calculation must arrive at results that are in line with the risk criteria established by the organisation during the framework phase [51].

2.3.4 Lists of threats/vulnerabilities

In terms of risk identification, ISO 27005 does not impose a closed, mandatory taxonomy, but provides extensive lists that serve as examples to be used in the assessment process [52]. Specifically, the standard includes:

- **List of Threats (Table A.10):** Provides examples of typical threats that can be used in the threat assessment process [52]. These threats are categorized according to their source into deliberate, accidental or environmental [53].
- **List of Vulnerabilities (Table A.11):** Provides examples of vulnerabilities in various security domains (Hardware, Software, Network, Personnel, Facilities, Organization), as well as examples of threats that can exploit these vulnerabilities [54].

These lists are designed to provide guidance to the organization to identify relevant risk scenarios. However, it is stressed that they are not exhaustive and that in some cases there may be other threats exploiting these vulnerabilities, so it is up to the organisation to adapt the lists to its own operational context [55].

2.4 Resources and Application

2.4.1 Complexity of implementation

The application complexity of ISO 27005 stems primarily from its versatility. As the standard does not offer ready-made solutions, it requires the organization to devote a significant effort to the Context Establishment phase to assemble the internal and external management environment [56].

The organisation is required to define its own operating parameters, such as risk criteria (acceptance and evaluation criteria) [57], as well as to choose the appropriate method to ensure that the results are consistent, valid and comparable [58].

As for the staff, the process cannot be carried out mechanically. It is necessary to involve people with specialist knowledge in the relevant field in order to collect the necessary information and properly assess risks [59]. In fact, especially when qualitative methods are used, the standard emphasizes that risk analysts should receive training and practice periodically to maintain their judgment alignment and reduce subjectivity [60].

2.4.2 Resources required (implementation costs)

The implementation of ISO 27005 entails significant operating costs, which do not concern the purchase of the standard or any specialized software, but primarily the commitment of human resources and administrative time. Top management has a responsibility to ensure that the necessary resources are available for risk management [61].

a) Human Resource Engagement and Collaboration: The methodology cannot be applied by one person in isolation. It requires extensive interaction within the organization:

- **Interviews:** Risk identification requires time for interviews with management and business process managers to identify relevant incidents [62].
- **Group Evaluation:** To increase the reliability of probability assessments, the standard proposes to conduct team assessments instead of individual assessments, thus engaging more executives [63].
- **Continuous Communication:** Communication and consultation with stakeholders should be continuous and not one-off [64].

b) Financial Planning: The process is inextricably linked to the economic cycles of the Agency. Risk assessments should be scheduled in time to be included in the annual budget for the approval of funds for the implementation of measures, while the Agency is required to monitor the total cost of ownership of the process [65].

c) Documentation (Bureaucracy): The standard imposes strict documentation requirements, as the existence of documented information is mandatory to demonstrate compliance [66]. The organization must maintain documents describing:

- The definition of the criteria and the methodology chosen.
- The results of the assessment (risk lists, risk owners).
- Risk response decisions and treatment plans [67].

3. Analysis of NIST Methodologies (SP 800-30 rev.1 and SP 800-39)

3.1 Introduction

Unlike the ISO 27005 standard which is a single guidance document, the US National Institute of Standards and Technology (NIST) approach is modular and is distributed in a series of Special Publications (SP). For the purposes of this comparative study, and in order to cover the corresponding range to that of ISO 27005, two fundamental documents are examined in combination:

1. **NIST SP 800-39 rev.1 (Managing Information Security Risk):** Sets out the general framework for an integrated, broad organization-wide risk management, defining strategy, governance, and monitoring [68].
2. **NIST SP 800-30 Rev.1 (Guide for Conducting Risk Assessments):** It serves as a supporting document, providing specialized instructions exclusively for conducting the Risk Assessment process. Its purpose is to specify and implement the guidelines of SP 800-39 rev.1 at the operational level [69].

The combined analysis of these two documents is necessary, as SP 800-39 sets the strategic framework and SP 800-30 analyses how the assessment is carried out, thus covering the risk management lifecycle holistically [70].

3.2 Identity and origin

3.2.1 Issuing Body and Origin

The Special Publications 800 (SP 800) series documents are published by the National Institute of Standards and Technology (NIST), which is an agency of the U.S. Department of Commerce [71]. The development of these guidelines stems from NIST's institutional obligations under the Federal Information Security Management Act of 2002 (FISMA - Federal Information Security Management Act, Public Law 107-347) [72]. This law gives NIST the responsibility for developing standards and guidelines, including minimum requirements, for the security of federal agency information systems [73].

An important element of their provenance is that both documents were developed within the framework of the Joint Task Force Transformation Initiative. It is an interagency collaboration involving representatives from the Civil, Defense, and Intelligence Communities, with the aim of creating a unified information security framework for the U.S. federal government [74].

3.2.2 Current Version

For the purposes of this study, and in order to be fully compatible with modern requirements, the current, current versions of the two documents are examined:

1. **NIST SP 800-39:** The current version of the document was published in **March 2011** [75]. It is worth noting that this document replaced and superseded the original version of SP 800-30 as the primary source of guidance for overall risk management [76].
2. **NIST SP 800-30 Rev.1:** The current version is Revision 1 and was published in September 2012 [77]. This revision was issued to align the evaluation process with the new strategic framework set by SP 800-39.

3.2.3 Legal nature

The legal nature of NIST documents varies significantly depending on the organization that implements them, presenting a dual nature:

1. **Mandatory:** For United States Federal Agencies, compliance with NIST safety standards and guidelines is mandatory and binding. This stems from the regulatory requirements of the FISMA Act and the guidelines of the Office of Management and Budget (OMB) [78].
2. **Voluntary Implementation:** For non-governmental organizations, academic institutions, and private sector enterprises (inside and outside the US), the use of these documents is optional. These organizations can voluntarily adopt them as a framework of best practices for risk management [79].

In addition, as works of the US federal government, these documents are not subject to copyright within the United States and can be used freely, although NIST requests that the source be acknowledged when using them [80].

3.2.4 Geographical Scope

Typically, the geographic scope of NIST's guidelines is limited to the territory of the United States, specifically the information systems of the federal government. The documents explicitly state that their guidelines apply to all federal information systems (except for national security systems, unless their use is also explicitly authorised) [81].

However, their true reach is global. NIST explicitly encourages state, local, and tribal governments, as well as private sector organizations, to consider the use of these guidelines [82]. In addition, a conscious effort is made to harmonize with international standards. The concepts and principles of the documents are designed to be compatible with International Organization for Standardization (ISO/IEC) standards, thus reducing the burden on organizations that need to comply with both NIST and international ISO standards [83].

3.2.5 Access Costs

In stark contrast to ISO standards that require the purchase of a license, access to the NIST SP 800 series documents is free and open to the public. NIST SP 800-39 and NIST SP 800-30 Rev.1, as works developed by a U.S. federal agency (NIST), are not subject to copyright restrictions within the United States. This means that they can

be used, copied and freely distributed by non-governmental organisations on a voluntary basis [84]. All NIST asks for is the citation of the source when using them [85]. All versions are readily available for download in electronic form (PDF) through the official website of the Computer Security Resource Center (CSRC) of NIST [86].

3.3 Purpose and architecture

3.3.1 Level of focus

Unlike the unified approach of other standards, NIST's architecture (as defined in SP 800-39) is characterized by a rigorously structured, multi-layered approach. The framework explicitly defines three hierarchical levels (Tiers) of risk management, which run vertically through the organization from the strategic to the tactical level, ensuring holistic coverage [87]. Specifically, the focus levels are:

1. **Tier 1-Organization View:** This is where governance, risk management strategy and risk tolerance are determined. Decisions at this level provide the framework and directly influence the activities of the downstream levels [88].
2. **Tier 2-Mission/Business Process View:** This is where critical operational processes are defined and prioritized and the operational architecture is designed. This layer acts as a bridge, translating Tier 1 strategic directions into specific security requirements for systems [89].
3. **Information Systems (Tier 3-Information Systems View):** It concerns the functional/technical level. It focuses on the specific information systems that support the operational processes. This is where the categorization of the systems takes place, as well as the selection, implementation and evaluation of technical security measures [90].

Communication between layers is two-way, ensuring that strategy is diffused to the systems and information about the state of the systems is uploaded to management for decision-making [91].

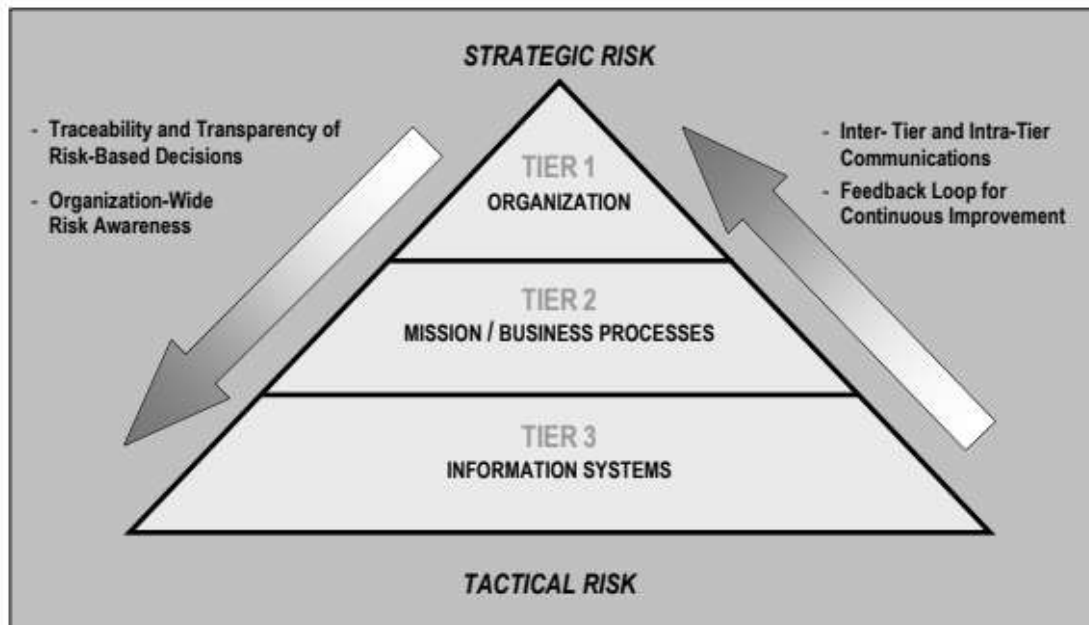


FIGURE 2: MULTITIERED ORGANIZATION-WIDE RISK MANAGEMENT

3.3.2 Relationship with other standards

The NIST SP 800-39 and SP 800-30 methodologies do not operate as standalone entities, but are integral parts of a broader, comprehensive suite of security documents developed by the Joint Task Force Transformation Initiative. Specifically:

- NIST SP 800-39: Explicitly labeled as the foundational document of the series. It sets the strategic framework and guides the other documents [92].
- NIST SP 800-30 Rev.1: Works in support of SP 800-39, specifying the evaluation process [93].

Their application is inextricably linked to other critical family standards:

- NIST SP 800-37 (Risk Management Framework-RMF): Defines the security lifecycle. The risk assessment (of SP 800-30) is performed at specific stages of the RMF [94].
- NIST SP 800-53 (Security Controls): Provides the list of security measures. Hazards identified with SP 800-30 are addressed by selecting controls from SP 800-53 [95].

Finally, it is worth noting the explicit intention to harmonize with international standards. The concepts and principles of these documents are designed to be compatible with ISO/IEC standards (such as ISO 31000 and ISO 27005), reducing the burden on organisations that have to comply with both frameworks at the same time [96].

3.3.3 Management Cycle

NIST's architecture does not follow the classic ISO cycle, but defines a specialized risk management cycle consisting of four interrelated components. The process is holistic and iterative, with the aim of continuous improvement [97].

The four steps of the cycle, as defined in NIST SP 800-39, are:

1. **Frame:** Defining the framework for decision-making (assumptions, constraints, risk tolerance).
2. **Assessment (Assess):** Identification and assessment of risks (threats, vulnerabilities, impacts).
3. **Response:** Taking measures to address the risk once it has been identified.
4. **Monitor:** Continuous monitoring of the effectiveness of measures and changes in the environment [97].

This process involves a feedback loop to continuously improve activities [98-100].

3.4 Risk Assessment Methodology

3.4.1 Assessment approach

NIST SP 800-30 Rev.1 explicitly states that risk and the factors that compose it can be assessed in a variety of ways. The standard distinguishes three main assessment approaches, allowing the organization to choose the one that best suits its culture and available data [101]:

1. **Quantitative Assessment:** It uses numbers where the importance and proportionality of values are strictly maintained (e.g., monetary amounts or probability percentages).

- **Advantage:** Effectively supports cost-benefit analysis for measure selection.
 - **Disadvantage:** Interpretation of the numbers is often required, while the rigor of the method is reduced when it is based on subjective estimates or uncertain data [102].
2. **Qualitative Assessment:** Uses non-numeric categories or levels (e.g., Very Low, Low, Medium, High, Very High).
- **Advantage:** Facilitates the communication of results to decision-makers.
 - **Disadvantage:** The range of values is small, making it difficult to prioritize risks reluctantly, while results can be subjective if there are no clear definitions [103].
3. **Semi-quantitative Assessment:** It uses scales or representative numbers (e.g. 0-10, 0-100), whose values do not necessarily correspond to real figures outside the scope of the assessment.
- **Advantage:** It combines the benefits of the above two methods, allowing for easier prioritization over the qualitative method, providing greater detail [104].

The choice of approach (or combination of them) depends on the culture of the organization, particularly in terms of its attitude towards uncertainty and risk communication [105].

3.4.2 Flexibility of methodology

Although NIST SP 800-30 Rev.1 contains highly detailed tables and scales, the text makes it clear that the methodology is characterized by maximum flexibility. There are no specific requirements on the formality, rigour or level of detail of a risk assessment, nor is there an obligation to use specific tools or techniques [106].

However, unlike ISO which lets the organization create scales from scratch, NIST provides a complete, ready-to-use model in Appendices D-I.

- **Character of Standards:** These standards (threat matrices, probability/impact scales) are explicitly described as 'indicative' and '**customizable**' [107].
- **Adaptability:** Organizations are encouraged to use these standards as a starting point and adapt them to their own specific circumstances [108].

- **Non-Compulsory Use:** The use of the specific tables and templates provided in the document is not mandatory for the purpose of carrying out the assessment [109].

In essence, NIST offers a "ready solution" approach that is changeable, unlike the ISO approach. It recognises that a single risk model cannot meet the diverse needs of all organisations and expects each organisation to define the model that suits its own perspective [110].

3.4.3 Risk calculation technique

NIST's fundamental equation defines risk as a function of two factors: (i) the likelihood of a threatening event occurring and (ii) the adverse impact that will occur if the event occurs [111].

To calculate the level of risk, the standard provides detailed tables and scales:

1. Scales: NIST suggests using a 5-level scale for all factors (Threat, Vulnerability, Probability, Impact). The levels are: Very Low, Low, Moderate, High, Very High [112].

- In the **semi-quantitative** approach, these levels are assigned to numerical scores (e.g., 0-100), allowing for greater precision in prioritization [113].

2. Risk Matrix: The calculation is usually done using a matrix as defined in Table I-2. There the Probability (rows) and the Incidence (columns) are combined to derive the final level of risk. For example, if the Probability is "High" and the Incidence is "Moderate", the Risk is calculated as "High" [114].

3. Flexibility in Calculation: The standard recognizes that risk may not be just a number, but a vector. This means that risk can be represented by multiple values, where different types of impacts (e.g., financial loss vs reputation) are assessed separately, rather than summed up into a single score [115].

Finally, NIST places a strong emphasis on capturing uncertainty. The calculation must be accompanied by an estimate of uncertainty stemming from incomplete data or subjective judgments [116].

3.4.4 Lists of threats/vulnerabilities

Unlike the more general approach of other standards, NIST SP 800-30 Rev.1 provides highly detailed and ready-to-use lists (taxonomies) in its appendices. The strategy proposed to the organization is not to discover threats from scratch, but to use these lists as a starting point with appropriate adaptation [117].

Specifically, the standard includes:

1. **Threat Sources Taxonomy:** Categorizes sources into four main groups: (i) Adversarial, (ii) Accidental, (iii) Structural, and (iv) Environmental [118]. It provides tables for assessing their characteristics, such as capability, intent, and targeting [119].
2. **List of Threat Events:** This is where NIST stands out by providing lists based on Tactics, Techniques, and Procedures. It describes specific attack scenarios (e.g., Phishing, SQL Injection, Social Engineering) and non-hostile events, allowing the organization to identify exactly how a threat might manifest [120].
3. **Vulnerabilities & Predisposing Conditions:** It provides lists of vulnerabilities, but also introduces the concept of "predisposing conditions". These are conditions that exist in the organization (e.g., location in a flood area or use of stand-alone systems) that increase or decrease the likelihood of a bad event occurring [121].

Implementation Strategy: NIST's strategy is "**adaptation**". The organization is asked to take these ready-made lists and remove what does not fit (e.g., if it does not have an opponent with specific capabilities) or to enrich them in more detail [122].

3.5 Resources and Application

3.5.1 Complexity of implementation

NIST's methodology is characterized by high implementation complexity due to the extent, detail, and interconnectedness of its documents. Its implementation is not limited to a single department, but requires the involvement of the entire organization, from top management (Tier 1) to system administrators (Tier 3) [123].

Specifically:

- **Specialization Requirement:** The process cannot be performed by unqualified personnel; the involvement of risk management professionals with specialized

knowledge, as well as people with technical expertise, is required to evaluate the systems [124]. NIST defines specific roles such as "Risk Executive", "Authorizing Official" and "Security Control Assessor", which require a high level of training [125].

- **Process Complexity:** The need for coordination between three levels (Organization, Operational Procedures, Systems) and the requirement for a two-way flow of information increases administrative complexity [126].
- **Data Management:** The volume of data generated (threats, vulnerabilities, audit results) is large and often requires automated tools to manage it, especially at the level of continuous monitoring [127].

However, having ready-made templates (such as threat lists) reduces the time required for the initial design of the methodology, compared to ISO which requires design from scratch.

3.5.2 Resources required (implementation costs)

Implementing the NIST methodology requires a significant investment of resources, primarily focused on human resource engagement and extensive documentation management. Although templates are available for free, the operational costs of implementing them are high.

a) Human Resource Engagement: The process requires the involvement of many different roles at all levels of the hierarchy. Time is required from senior management (Heads of Agencies, Chief Executive Officers) to define strategy and risk tolerance [128]. In addition, the active involvement of specialized roles such as "Risk Executive", "Authorizing Officials" and "Security Control Assessors" is required; who are responsible for decision-making and the evaluation of controls [129].

b) Documentation and Paperwork: NIST imposes strict documentation requirements. Each step of the process must be recorded in detail. In particular, the evaluation process produces comprehensive reports that must include a description of the purpose, scope, assumptions, limitations, models used, and results [130]. The need for record-keeping for each security audit significantly increases the administrative burden.

c) Continuous Monitoring: Unlike a one-off assessment, NIST requires continuous monitoring. This commits permanent resources to verify compliance and check the effectiveness of measures over time [131]. To reduce these costs, the standard

encourages the use of automated tools where feasible, as manual monitoring is time-consuming and accurate [132].

4. Benchmarking and Conclusions

4.1 Summary Table of Criteria

The table below presents the comparative overview of the ISO/IEC 27005:2022 standard and the NIST SP 800-30 Rev.1 and SP 800-39 guidelines, based on the four thematic axes defined in the methodology of the work.

Comparison Criteria	ISO 27005	NIST SP 800-30 rev.1 and SP 800-39
Identity and Origin		
Issuing Body	International Organization for Standardization (ISO) and IEC.	U.S. National Institute of Standards and Technology (NIST)
Current Version	October 2022 (4th edition)	SP 800-39: March 2011 and SP 800-30 Rev.1: September 2012
Legal Nature	Voluntary International Standard (Guidance)	Mandatory for U.S. Federal agencies, voluntary for individuals
Geographical Reach	Worldwide standardization	Typically US, practically global with an intention to harmonize with ISO
Cost of Access	Paid (Copyright).	Free (U.S. Government Project No Copyright).
Purpose and Architecture		
Focus Levels	Operational Assets: Operational Procedures and Information Supporting assets: Hardware, software, networks, personnel	Three hierarchical levels: 1. Organization 2. Operational Procedures 3. Information Systems
Document Structure	Single guidance document	Modular structure (SP 800-39 for strategy SP 800-30 for evaluation)

Management Cycle	6-Step Process (based on ISO 31000): 1. Define a framework 2. Evaluation 3. Treatment 4. Acceptance 5. Contact 6. Monitoring Feature: Runs in two cycles Strategic and Operational	Repeat cycle of 4 interrelated steps: 1. Framing 2. Evaluation 3. Response 4. Monitoring
Risk Assessment Methodology		
Assessment Approach	Based on Events: Strategic Scenarios or Asset Based: Business Scenarios	Three Assessment Approaches: 1. Quality 2. Quantitative 3. Semi-quantitative
Flexibility of Methodology	It acts as a non-prescription standard and allows each organization to choose or develop its own method entirely. Examples are non-binding and scales are set by each organization.	It offers a "ready solution" approach, providing complete templates as a starting point. Their use is optional and fully adaptable to the needs of each organization
Risk Calculation	Free determination. Usually: Probability X Consistency with the ability to include the value of the asset	Use of a risk matrix with predefined 5-level scales (Very Low-Very High) and mandatory recording of uncertainty
Threat/Vulnerability Lists	Sample lists with examples of typical threats and vulnerabilities to <u>help</u>	Event lists based on tactics and techniques. Customizing lists by organization
Resources and Application		

Implementation Complexity	High effort in establishing a framework. Due to the lack of ready-made solutions, the organization defines criteria and methods on its own. Specialized knowledge and periodic training of analysts are required to reduce subjectivity	High administrative and structural complexity. Requires 3-level coordination and involvement of specialized roles. Automated tools are recommended for the management of large volumes of data. Existence of ready-made templates for faster, initial planning
Resource Requirements	Mainly Operating Costs: • Coordination with economic cycles • Time Commitment for Interviews and Group Assessments	High Operating Costs: • Engaging Specialized Roles • Permanent resources for continuous monitoring • Strict Record-Keeping

4.2 Conclusions of Theoretical Comparison

Comparative review of the two frameworks highlights that the choice between ISO 27005 and the NIST SP 800 series of guidelines is not just a technical dilemma but a strategic decision that impacts the organization's management culture. The main difference is found primarily in the implementation approach, where two different philosophies collide.

ISO 27005, acting as a high-level guide, offers the organization the freedom to design methodology from scratch, linking assets to operational objectives. This flexibility, however, shifts the burden of effort to the initial phase of establishing the framework, as it requires the management to autonomously define the criteria and scales. On the other hand, NIST offers a more practical starting point, providing ready-made taxonomies, templates, and scales, solving the problem of original design. The price of this facility is increased administrative complexity, as its implementation requires the coordination of three hierarchical levels (Tiers) and the commitment of specialized roles, making it a structurally "heavier" process.

In addition to the structure, the difference in the depth of the technical analysis is also distinguishable. While ISO focuses more on strategic alignment and connection to economic cycles, NIST delves into technical details, introducing concepts such as the use of vectors to represent risk, mandatory recording of uncertainty, and tactical and technical-based analysis (TTPs). This technical excellence, combined with the fact that it is available free of charge as a public good - in contrast to the commercial nature of ISO - makes it attractive for organizations looking for immediate expertise and a rigorous methodology.

In conclusion, the two standards should not be treated as mutually exclusive, but often as complementary. In practice, an organization can pursue ISO 27001 certification for regulatory compliance and extroversion purposes, while using NIST's rich material (such as threat lists) as the functional mechanism of the assessment. ISO 27005 is therefore ideal for those who prioritize flexibility and international recognition, while NIST is the best choice for organizations that require detailed guidance, ready-made tools and rigorous technical documentation, as well as for those subject to a regulatory obligation to comply with US federal standards.

5. Introducing Software Tools

5.1 Introduction

Before the technical presentation and evaluation of specialized software tools (GRC Tools), it is considered appropriate to capture the practical reality of the market. In the context of the present study and following a personal communication with a current Chief Information Security Officer (CISO) in Athens, a significant discrepancy was identified between the theoretical availability of tools and their practical application.

In particular, it was pointed out that the adoption of specialized risk management platforms is not the norm for the majority of businesses. With the exception of large multinational organizations and leading auditing firms, most companies tend to follow two alternative practices:

1. **Extensive use of Microsoft Excel:** The dominant trend among small and medium-sized enterprises is the use of general-purpose software, especially Microsoft Excel. These organizations rely on customized spreadsheets and internal processes to record and monitor risks. This choice is dictated by the need for flexibility, the immediate familiarization of staff with the tool and the avoidance of licensing costs for new applications.
2. **Outsourcing:** At the same time, it is often observed that security audits are outsourced. Through this practice, companies avoid the complexity of internal tool management, as they receive the results of the audits ready, transferring the responsibility of methodological and technical support to the external provider.

In this light, the following examination of the tools (SimpleRisk, Monarc, Verinice, EAR/PILAR) is carried out on the basis of a new, distinct evaluation framework. The aim of this section is the objective assessment of their characteristics and capabilities, through the application of specific criteria defined for the needs of the present study. In order for the comparison to be holistic, the criteria were classified into three distinct axes:

1. **Technical Identity and Licensing:**

The first axis concerns the availability and technical requirements of the application, elements that are decisive for the sustainability of the solution in an organization:

- **Licensing Model:** It is examined whether the software is Open Source, Commercial or offers a free version with restrictions (Trial).
- **Free Distribution Range:** It is evaluated whether the free version is full, Beta/Demo or limited in time, as well as whether it allows productive use without hidden costs.
- **Architecture and Requirements:** Separation between Web-based applications, which favor multi-user collaboration, and standalone office applications (Desktop/Standalone). At the same time, the complexity of the installation and the requirements in computing resources are examined.

2. Risk Management Functionality:

The second axis examines the essence of the process, i.e. whether the tool can support a comprehensive risk study:

- **Asset Management:** The ability to massively import, categorize, and price the organization's assets.
- **Pre-installed Libraries:** Perhaps the most critical functionality criterion. It is examined whether the tool provides ready-made lists of threats, vulnerabilities and security measures (based on ISO 27001/27002 or NIST SP 800-53), exempting the user from manual entry.
- **Calculation Mechanism:** The ability to customize the way the risk is calculated (e.g. creating a custom Risk Matrix) to match the organization's methodology.
- **Reports:** The ability to export dashboards and final reports (in PDF/Excel format) for presentation to the administration.

3. User Experience:

- **Interface:** The ergonomics, ease of navigation and learning curve of the tool are evaluated, as an unwieldy environment is often a deterrent to its adoption over simpler spreadsheets.

5.2 Tools

5.2.1 SimpleRisk

5.2.1.1 Technical Identity and Licensing

In this section, the technical characteristics and the distribution framework of SimpleRisk are analyzed, elements that determine the possibility of access and use by an organization.

- **Licensing Model:** SimpleRisk follows the "**Freemium**" model. The basic installation of the tool (SimpleRisk Core) is available free of charge through the company's website, allowing the user to download and install the core of the application at no cost. However, any additional functionality required is not included in the free version and must be purchased separately by the respective customer [133].
- **Free Distribution Range:** During the process of downloading the software for local installation, a significant accessibility limitation was found. The manufacturer implements a strict control policy, prohibiting the download of the application to individuals (individuals). In particular, the system does not accept addresses from public email providers (such as Outlook, Gmail, Yahoo), allowing the download of the installation file exclusively to corporate personnel with Professional domain [134].

Evaluation and Testing Options: For users who wish to evaluate the software before proceeding with an installation or purchase, the company provides three distinct options, with varying degrees of freedom [135]:

1. **30-day Free Trial:** This is a fully hosted version that includes all the paid benefits they offer. However, this option is strictly available for business use and requires corporate registration.
2. **Live Demonstration:** This refers to a live presentation of the tool's capabilities by a representative of the company. This

option is not immediate (on-demand), as it requires the interested customer to contact the sales department to schedule the session.

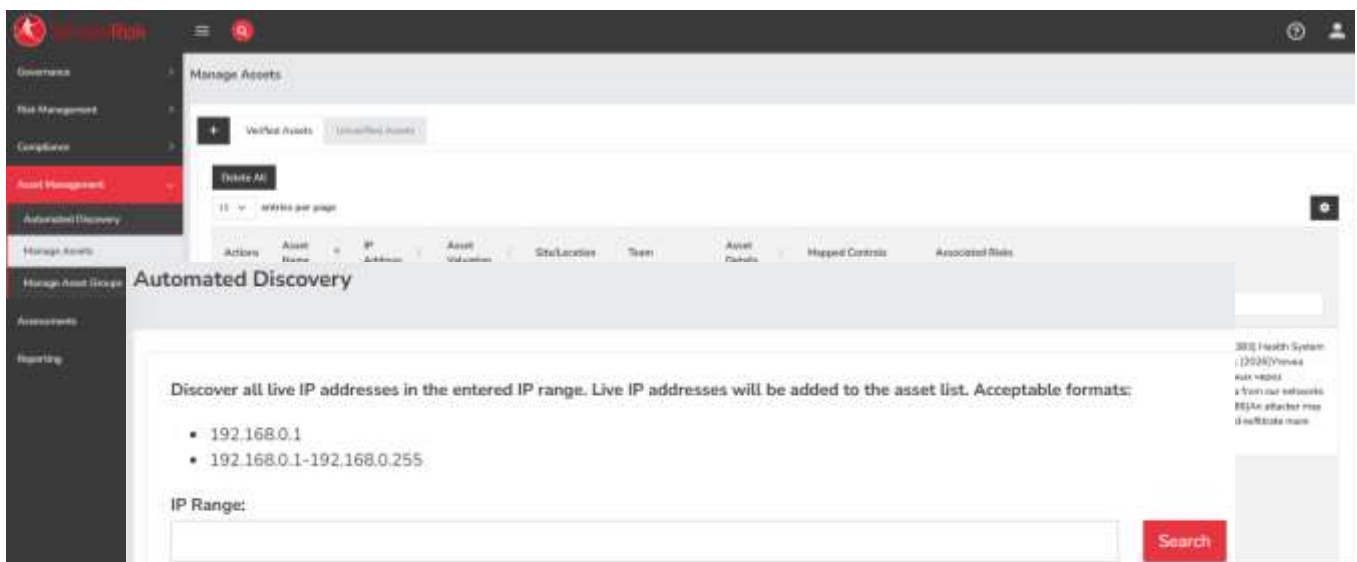
3. **SimpleRisk Sandbox:** This is the option used for the purposes of this study. It is an online simulation of the full functionality of the application. Through the Sandbox, direct access to the interface is provided without the need for installation. Although it is a complete representation of the application, it is subject to functional limitations, which do not prevent the evaluation of risk management processes.

- **Architecture and Requirements:** SimpleRisk is a web-based application, allowing simultaneous access of multiple users via a browser. The system requirements are particularly low, as it requires a standard server with minimal features: a 2-core processor (CPU), 2 GB of RAM and 20 GB of storage [136].

5.2.1.2 Risk Management Functionality

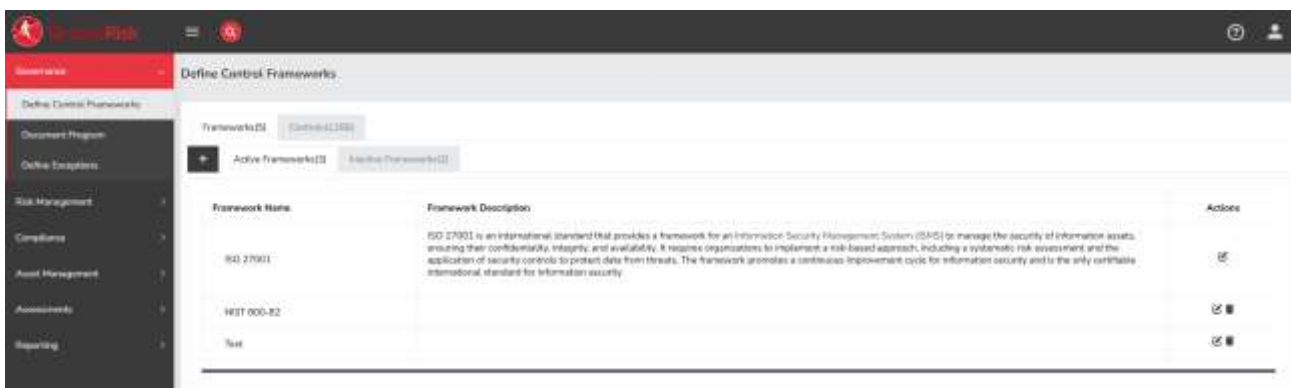
Through the examination of the simulation environment (Sandbox), the completeness of the tool was evaluated in the four main axes of functionality:

- **Asset Management:** The tool has robust mechanisms for inventorying and valuing assets. As reflected in the "**Manage Assets**" option, each asset comes with an Asset Valuation field (e.g., "\$200,000 to \$300,000"), allowing for financial risk weighting. In addition, SimpleRisk addresses the need for bulk listing through the "**Automated Discovery**" feature , which allows for the



scanning of IP addresses (IP Range Scan) to automatically detect and register devices, drastically reducing the burden of manual entry [137].

- **Pre-installed Libraries:** The software provides ready-made libraries that meet international standards. In the **"Define Control Frameworks"** screen, enabled frameworks such as ISO 27001 and NIST 800-82 were detected, while in the **"Self Assessments"** section there are ready-made questionnaires for PCI DSS 3.2 concerning the security of card transactions and HIPAA governing the security of medical data. the user has at his disposal the **"Threat Mapping"** field, which links the incident to standardized threats (e.g. "Hacking & Other Cybersecurity Crimes"), as well as the **"Control δRegulation"** field for direct



correlation with regulatory requirements [137].

- **Calculation Mechanism:** The platform supports dynamic calculation and monitoring of risk evolution. On the **"Plan Mitigation"** screen, the Inherent

Plan Mitigation

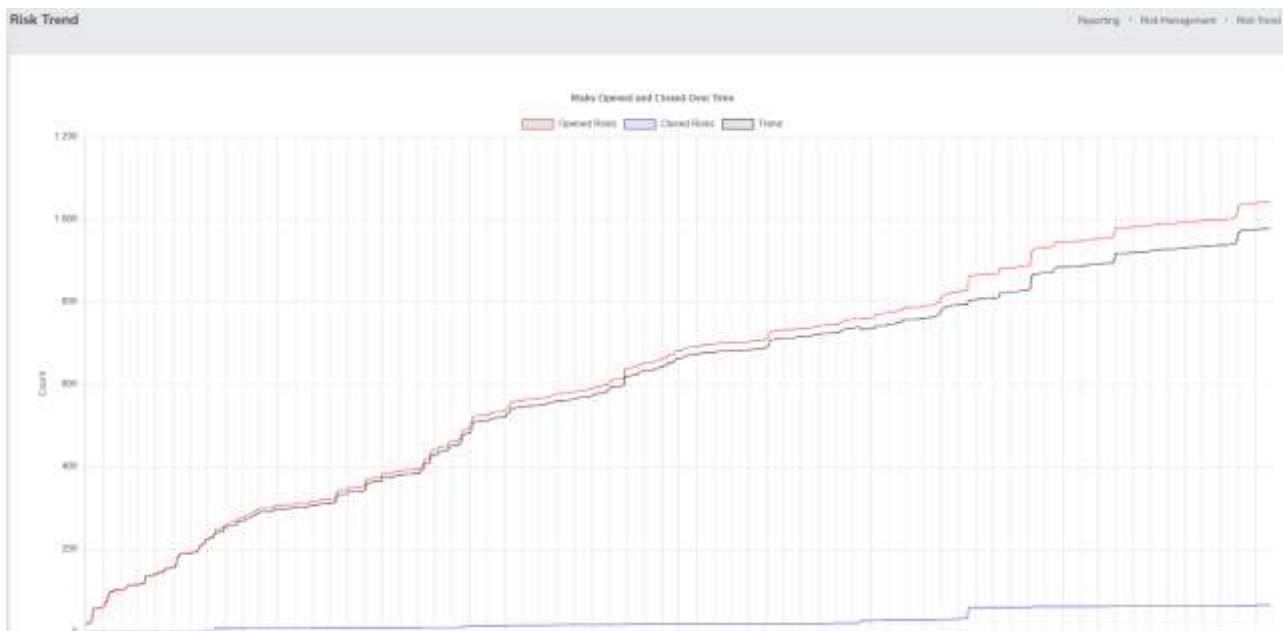
Below is the list of submitted risks that require mitigation planning.

10 entries per page

ID	Status	Subject	Inherent Risk (Current)	Submission Date	Date Closed	Risk Source	Team	Owner	Risk Scoring Method	Residual Risk (Current)	Project	Mitigation Planned	Plan Size
1007	New	DDoS Attacks	10	03/09/2023 1:17 PM CST		External			Contributing Risk	10		High	10
1010	New	Attackers can scan for remotely accessible network services that are vulnerable to exploitation	10	12/16/2022 7:30 PM CST					Custom	10		High	10
1011	New	log4j	10	03/19/2023 6:25 AM CST					Classic	10		High	10
1020	New	Attackers can exfiltrate data from our networks compromising the privacy and integrity of sensitive information	10	12/16/2022 7:30 PM CST					Custom	10		High	10
1023	New	Attackers can gain wireless access and bypass our security perimeters in order to steal data	10	12/16/2022 7:30 PM CST					Custom	10		High	10

Risk and the Residual Risk are displayed separately with clear numerical values. At the same time, the system offers multiple scoring methodologies through the **"Risk Scoring Method"** field (options such as Classic, Custom, Contributing Risk), allowing the organization to adapt the algorithm to its own needs [137].

- **Reporting:** The ability to draw conclusions is enhanced by advanced visualization tools. The **"Risk Dashboard"** provides pie charts for the distribution of risks by level (High, Medium, Low) and by location (Site/Location). Particularly important is the **"Risk Trend"** report, which displays in a line graph the historical evolution of open and closed risks over time, offering management a clear picture of the a tendency to improve or deteriorate the security of the organisation [137].



5.2.1.3 User Experience

The interface of SimpleRisk is distinguished by its modern and neat aesthetics, which is significantly different from the cold image of traditional spreadsheets. The application leverages strong visuals, and easy-to-read graphs on the main dashboard, offering the user an immediate and pleasant visual overview of the organization's security posture. Navigation is based on a fixed column, which organizes operations clearly, while practicality is enhanced by intelligent workflow mechanisms. Despite its

ergonomic design, the tool's range of capabilities may initially be strange or difficult for the new user. This is particularly noticeable in the Reports menu, where the plethora of options available - from simple dashboards and trend charts to advanced visualization tools - creates a dense information environment. The existence of so many alternatives, although it proves the completeness of the application, increases the complexity and requires familiarization time for the user to locate exactly what they need without getting lost in the options. However, once this learning difficulty is overcome, SimpleRisk proves to be an extremely powerful and high-quality application, capable of meeting the needs of even the most demanding organizations [137].

5.2.2 Monarc

MONARC (Method for an Optimized Analysis of Risks by CASES) is a unique case in the field of GRC tools, as it does not come from a private software company, but was developed as a government initiative. In particular, it was created by the Luxembourg CASES (Cybersecurity Agency for the Security of the Economic Sector), which is now part of the country's National Cybersecurity Competence Center (NC3) [154].

5.2.2.1 Technical Identity and Licensing

- **Licensing Model:** The software is strictly open source and is available under the GNU Affero General Public License version 3 (AGPLv3). The choice of this license is of strategic importance, as it ensures that the tool remains free and that any modification to the code, if made available over a network, must also be published under the same license. MONARC was developed as a "public good" with the aim of enhancing the security of the non-profit-making enterprises [154].
- **Free Distribution Range:** Due to the nature of the project, there is no distinction between free and commercial versions. The user has access to the

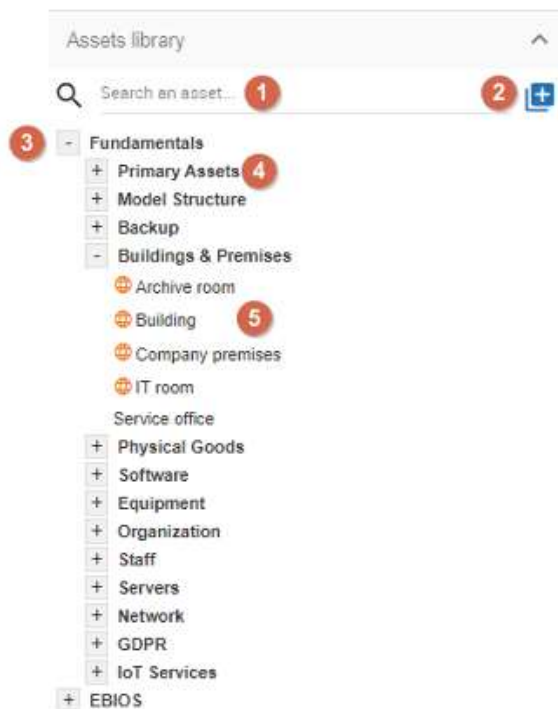
full features of the tool without any financial restrictions or "locked" features [154]. For the installation of the tool, three main methods are offered that cater to different needs:

1. **Pre-installed Virtual Machine (OVA):** For immediate testing without complex settings, via simulation software (e.g. VirtualBox) [155].
 2. **Docker Containers:** The recommended method for production operation, which offers ease of management and upgrades [156].
 3. **Download Source Code:** Possibility of manual installation directly from GitHub for specialized configurations [156].
- **Architecture and Requirements:** MONARC is a purely web-based application, designed for collaborative use. Technologically, the backend is developed in Python (Django framework) and the frontend in JavaScript (AngularJS), while using MySQL/MariaDB as the database. The system requirements for the virtual machine are modest, requiring at least 4 GB of RAM and 20 GB of free disk space [156].

5.2.2.2 Risk Management Functionality

At the heart of MONARC is its structured risk analysis process, which closely follows the methodology of ISO/IEC 27005. The tool guides the user through a hierarchical approach, allowing for detailed modeling of the organization.

- **Asset Management:** Asset management in MONARC is implemented through a dynamic tree structure (Asset Tree). The system clearly separates assets into two main categories, following the logic of dependencies:
 - **Primary Assets:** These include business processes and information that have direct value to the organization. Impacts are defined here in the event of a breach of confidentiality, integrity, or availability [157].
 - **Supporting Assets:** These include hardware, software, network and human resources. These elements "inherit" the value from the primary goods and are the places where threats and vulnerabilities apply [157].



1. Search area in order to quickly find an asset.
2. Button for creating/importing assets (see [Create an Asset](#)).
3. Categories level of the Library. There are usually two categories as follows:
 1. **Fundamentals**: Contains all default assets offered by NC3.
 2. **EBIOS**: Contains assets inspired by EBIOS. These are assets containing non-optimized risk models.
4. Sub-categories level.
5. Asset level: These are the assets that must be dragged and dropped to the Risk Analysis area.

- **Pre-Installed Libraries:** One of the strongest features of MONARC is the built-in "Knowledge Base". The tool does not require the user to import data from scratch, as it provides:
 - **Object Libraries:** Ready-made asset classes (e.g. Servers, Laptops) with predefined properties [158].
 - **Threat and Vulnerability Lists:** Each asset type is automatically linked to relevant threats and vulnerabilities, based on standards such as ISO 27005 and CASES specifications. This speeds up the analysis process and ensures that critical risks are not omitted [158].

Asset import center

Import method:

☐ By duplicating
 ☒ By merging

Only global assets can be imported by merge.

List of common MONARC assets

Search an asset...

Name	Category	Asset type	Actions
Front Office	Model Structure	Container	
Specific software	Software	Software	
Specific software maintenance	Software	Software maintenance	
User workstations	Equipment	Desktop computer	

1. Table of available assets in the MONARC common Library.
2. **Action:** Initiate the import procedure for the corresponding asset.

- Calculation Mechanism:** The risk calculation in MONARC is semi-quantitative and based on Risk Matrices. The process follows the following steps:
 1. **Impact Assessment:** The impact on primary goods is defined on a scale (usually 0-4) for the C-I-A (Confidentiality, Integrity, Availability) parameters.
 2. **Probability Assessment:** Calculates the probability of the threat appearing on supporting goods.
 3. **Risk Calculation:** The tool automatically calculates the Inherent Risk by multiplying the incidence by the probability. Then, taking into account the existing safety measures, it generates the residual risk (Residual Risk), coloring the results based on the defined Risk Acceptance Threshold [159].

Search an asset...

MyPrint [EN]

IoT

Printing department

Printing operators

Back Office Rotary printing press

System administrator

Building

Network and Telecom

Rotary printing press

Computer graphics department

Front Office

Back Office

GDPR legal obligations

Information risks

Operational risks

74 information risks

Risk threshold (on max CIA)

Keywords

Asset	Impact			Threat		Vulnerability	
	C	I	A	Label	Prob.	Label	Existing c
Printing operators	1	2	3	Error in use	3	Users are not made aware of information security	The person in place doe He is retiring soon.
Printing operators	1	2	3	Error in use	3	No IT charter specifying the rules of use	No charter in place.

1. The information risk table is based on CIA^[1] criteria.
2. The operational risk table is based on ROLFP^[2] (see [Operational Risks](#))

Depending on your selection, the display risk table may change:

Selection	Information Risks	Operational Risks
Root of analysis	All risks of analysis	All risks of analysis
Primary Asset	Risks associated with its supporting assets	Risks associated with themselves
Supporting Asset	Risks associated with themselves	No risks

- **Reports:** MONARC's reporting system is designed to cater to both technical and administrative requirements. Through the "Dashboard" and the export menu, the user can get:
 - **Risk Table:** A detailed representation of all risks, classified by criticality [160].
 - **Risk Treatment Plan:** A report that includes the proposed measures, the implementers and the timeline.
 - **Statement of Applicability:** The tool automatically generates the SoA document, which is a prerequisite for ISO 27001 certification. This functionality is based on the dynamic matching of the user-selected mitigation measures with the standard controls, documenting which

safeguards are applied and why, without the need for manual writing [160].



All the part of the dashboard have the same functionalities.

1. **Choose** the part on which a dashboard is required.
2. **Export** all the data in a XLSX document to make your own graph.
3. **Change** the paramaters of the selected chart.
4. **Export** the chart as PNG

5.2.2.3 User Experience

It is noted that the evaluation of this section was based on the study of the user manuals, as technical limitations did not allow the software to run in a simulation environment (VMware Pro). According to the documentation, the user experience at MONARC is characterized by an effort to simplify the complex risk management process, offering a modern and friendly online environment that can be accessed through any browser. The interactive 'Dashboard' provides a direct view of security with graphs, helping to quickly identify threats [161]. The recording of assets is done through a tree structure that supports the automatic transfer (heritability) of effects, saving significant time [162]. Finally, the ready-made libraries and ease of use make the tool accessible even to non-skilled users, without the need for complicated settings [163].

5.2.3 Verinice

5.2.3.1 Technical Identity and Licensing

Verinice is one of the most recognized European GRC solutions, with a strong foundation in Germany and an emphasis on ISO 27001 and BSI IT-Grundschutz standards. BSI IT-Grundschutz is the German Government's reference standard for information security. In contrast to the more general approach of ISO 27001, IT-Grundschutz provides a detailed and rigorous methodology with specific technical lists of measures (Compendium) for each element of the infrastructure (e.g. operating systems, networks, building infrastructure). Verinice natively integrates these catalogs, making it ideal for organizations that require compliance with stringent European standards [138].

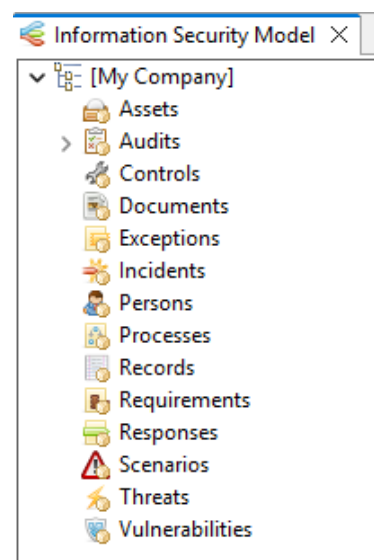
- **Licensing Model:** Officially, the source code is freely available, allowing for free review. However, the company charges for the provision of the ready-made, executable program through a subscription to the "Verinice Shop" [139]. In practice, this means that while the code is open, the service of easy installation and immediate operation is treated as a commercial product [138].
- **Free Distribution Range:** For assessment and training purposes, the verinice version is available. EVAL. This is a version that, although it provides full functionality for the creation of an Information Security Management System (ISMS), carries a critical limitation that makes it unsuitable for professional use. It does not allow the generation of reports and the export of data. To remove this restriction and make full use of the software, the user is invited to switch to the commercial version. The cost for the acquisition of the ready-to-use software amounts to €714.00 (including VAT) per year, an amount that essentially concerns the service of distribution and support of updates. At the same time, for reasons of economy, the option of the two-year subscription is promoted with a total cost of €1,285.20, which offers a clear financial benefit compared to the annual renewal [139].
- **Architecture and Requirements:** The tool is in a technological transition stage, offering two distinct architectural approaches [138]:

1. **Verinice.Client (Desktop):** This is the stable and widely used version of the software (the one installed for the test). It is compatible with Windows, macOS and Linux operating systems, and requires the user to have a Java environment (JRE) to operate. As a locally running application, it uses the user's system resources. The minimum requirements for the standalone version to run smoothly are 4 GB of RAM (with a minimum acceptable of 1 GB) and 4 GB of free hard disk space to store the local database. In contrast to web applications, here the processing power is borne by the user's computer, so a modern processor is recommended for faster execution of risk analyses [140].
2. **Verinice.veo (Web-based):** This is the new generation of the tool, which is purely web-native (cloud-native) and allows use via a browser [138]. However, this version is mainly promoted as a commercial solution or with a time-limited trial (30 days) and is not freely available for local installation such as the Desktop Client version [139].

5.2.3.2 Risk Management Functionality

Verinice's operational approach focuses on rigorous standardization and hierarchical modeling, offering specialized tools for every stage of the risk management lifecycle.

- **Asset Management:** In contrast to simple inventory lists, Verinice adopts a Tree Structure for capturing assets [141]. In addition, bulk import of data from external sources (CSV, XML) is supported, as well as the use of special "import agents" to extract data from existing network inventory tools (e.g. Network Inventory) [138].



- **Pre-installed Libraries:** This is the most important advantage of the tool. At startup, Verinice does not require the user to import data from scratch, but provides ready-made "Perspectives" based on international standards. In particular, it fully integrates the ISO/IEC 27001 standard (for the creation of ISMS), the detailed directories of BSI IT-Grundschutz (with thousands of ready-made threats and measures), as well as the VDA/ISA standard for the automotive industry [138]. The existence of these libraries allows for instant mapping of vulnerabilities and security measures without manual typing [141].
- **Calculation Mechanism:** The risk analysis process is standardized and



explicitly based on the ISO/IEC 27005 standard. Through the special "Run ISO/IEC 27005 Risk Analysis" function, the tool automates the correlation between the assets, threats and vulnerabilities selected by the libraries. The user has the ability to define the level of impact and probability, while the system

automatically generates the risk results for the selected organizations or parts of the infrastructure [141].

- **Reports:** This is where the most important separation between publications is located. While the platform has the ability to generate rich reports (such as risk plan, aggregated dashboards), this functionality is locked in the free version (EVAL) [139]. In the full commercial version, reports are produced in editable formats (Word, Excel, PDF), allowing them to be presented directly to the administration or external auditors.

5.2.3.3 User Experience

The experience of using Verinice is characterized by a stark contrast between the content and the complexity of the interface, which is judged to be the weakest point of the software. The graphical interface, based on older technology (Eclipse RCP), is visually "loaded", with an abundance of windows and tabs that create confusion for the user. Learning the tool is difficult and demanding, as the way it works is not clear. As seen in the test, even with the help of the operation demo video, the process remains confusing for a novice user. However, an important counterweight to its unwieldy nature is the quality of the built-in libraries. Having ready-made lists and standards (such as ISO 27001, BSI IT-Grundschutz, VDA/ISA) works redemptively, offering a ready-made compliance structure for specialized industries. In conclusion, Verinice is a powerful yet hard-to-reach solution that, while offering ready-made content, requires a significant investment of time and effort to learn [141].

5.2.4 EAR/PILAR

The EAR/PILAR suite of tools is the standardized software solution widely used in the Spanish Public Administration for risk management. It is developed with the strategic support of the Spanish National Center for Cryptology (CCN). The tool is strictly based on the MAGERIT methodology (official risk analysis and management methodology of the Spanish Government), while also supporting international standards such as ISO/IEC 27002:2022 and ENS 2022. The software is not one, but it

comes in four distinct versions depending on the complexity of the organization [142, 143]:

- **μPILAR:** Intended for small systems that follow a homogeneous security approach, offering rapid analysis.
- **PILAR Basic:** Aimed at users who need a standard risk analysis. It provides organization capabilities in security areas and supports the use of security measures.
- **PILAR RM (Risk Management):** It is the full version for risk management. It allows detailed customization (e.g. threat management, profiling) and supports multiple user levels and advanced reporting.
- **PILAR BCM (Business Continuity Management):** Specialized publication for Business Continuity Management. It focuses on the calculation of RTO-Recovery Time Objectives and RPO-Recovery Point Objectives [143].

5.2.4.1 Technical Identity and Licensing

The EAR/PILAR family of applications follows a single technical and commercial approach in all its versions (μPILAR, Basic, RM, BCM). Although each version caters to a different organization size, they share the same software core and licensing framework.

- **Licensing Model [142]:** The software is proprietary and commercial. Licensing is flexible and offers two distinct ways of acquisition, which apply to all versions of the application:
 - **As a service (annual subscription):** This refers to an annual rental of the license. The advantage is the lower initial cost and the inclusion of all upgrades that will be released within the year.

tool	size S	size M	size L
number of users	1	5	10
μPILAR	100 €	200 €	400 €
PILAR Basic	200 €	400 €	800 €
PILAR BCM	350 €	700 €	1,400 €
PILAR RM	500 €	1,000 €	2,000 €
PILAR RM + BCM	700 €	1,400 €	2,800 €
PILAR + BBDD	+30%	+30%	+30%
RMAT	750 €	1,500 €	3,000 €

**It concerns the annual rental of the license with all new versions.*

- **As a product (one-time purchase):** This refers to the purchase of a perpetual license for this version. The user pays once and owns the software forever. However, a separate maintenance contract is required for future upgrades.

tool	size S	size M	size L
number of users	1	5	10
μPILAR	250 €	500 €	1,000 €
PILAR Basic	500 €	1,000 €	2,000 €
PILAR BCM	1,000 €	2,000 €	4,000 €
PILAR RM	1,500 €	3,000 €	6,000 €
PILAR RM + BCM	2,000 €	4,000 €	8,000 €
PILAR + BBDD	+30%	+30%	+30%
RMAT	2,250 €	4,500 €	9,000 €

**Owners of a previous version who wish to switch to the current one are entitled to an 80% discount on the original price of the product. Optionally, at an annual cost equal to 20% of the purchase value, automatic access to all new versions is provided for the duration of the contract.*

Important notes:

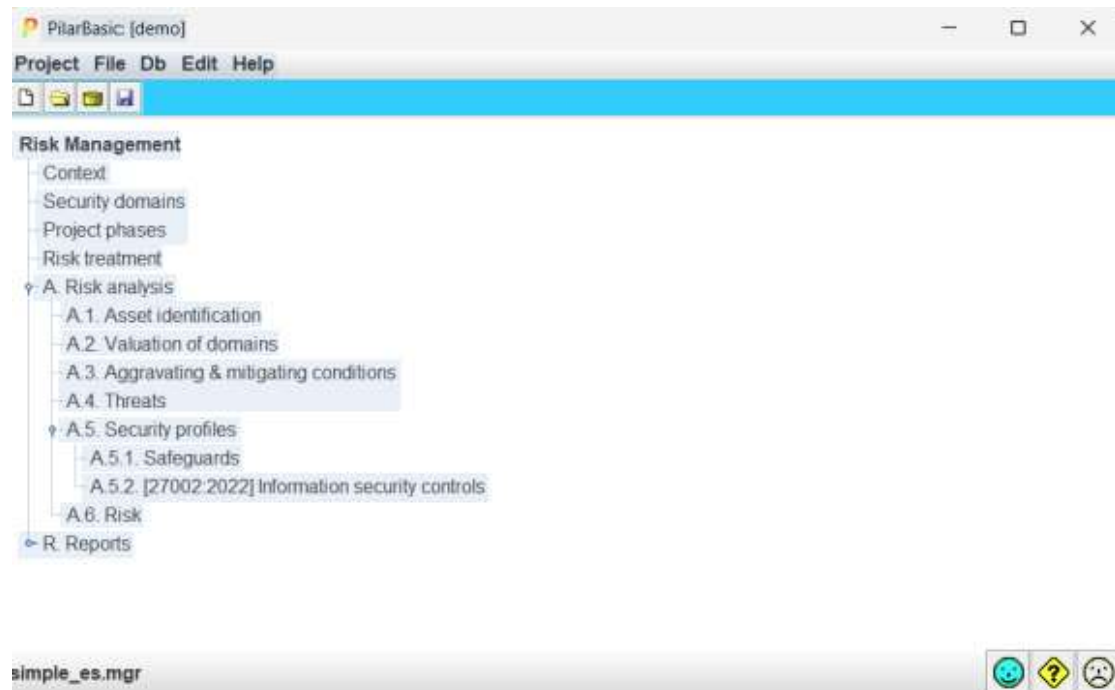
- **PILAR + BBDD:** Additional function for RM version that allows data to be stored in a database for collaborative work of large teams.
 - **RMAT:** A separate customization tool that allows specialized users to create custom libraries of threats and security measures.
- **Free Distribution Range [142]:** The free distribution policy is common to the entire PILAR family and is divided into two levels of use:
 - **Viewer Mode (Free):** Anyone can use the software for free to open and read analysis files, but without the right to modify.
 - **Evaluation mode:** A full test is available for 30 days. However, in all manuals (μPILAR, Basic, RM) it is explicitly emphasized that this version has specific functional limitations:
 1. Does not allow the generation of reports
 2. It only calculates a limited number of risks

- **Architecture and Requirements [142]:** The technical basis is common to all variants, as they are all based on the Java programming language. This gives the application specific features listed in the "First Time" installation guides of each version:
 - **Software Requirements:** The only strict requirement mentioned is the existence of the Java Runtime Environment (JRE), version 8 or higher. No specific operating system is required, as the application is compatible with Windows, Linux, and macOS.
 - **Application:** The architecture of the application is designed to work without a classic installation. The user simply unzips the folder and executes the file (executable .exe or .jar), which allows it to be operated even from a USB flash drive, without requiring administrator privileges on the machine.
 - **Data Management:**
 - μ PILAR and Basic versions work with local files (.mgr), storing data at the file system level.
 - The RM version is the only one that differentiates architecturally at this point, as it additionally offers the possibility of connecting to a database to manage large volumes of data.

5.2.4.2 Risk Management Functionality

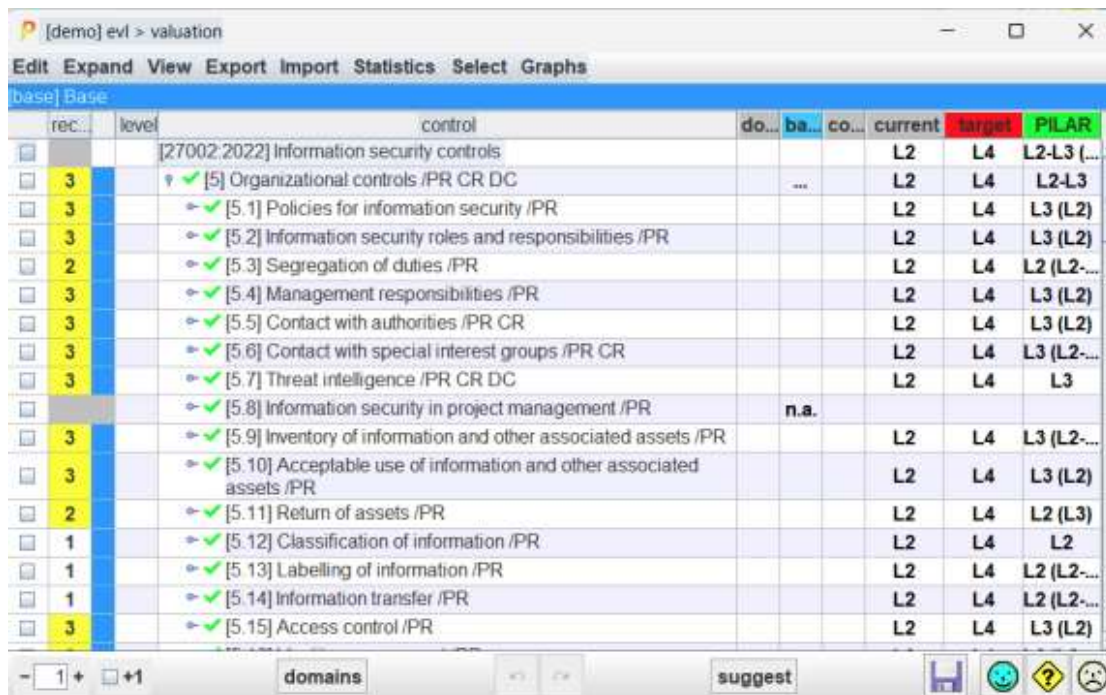
- **Asset Management:** The basis of the MAGERIT methodology is to identify and prioritize the assets that have value to the organization [144]. PILAR Basic implements this process through two steps that appear on the main screen:
 - **Identification:** The user is asked to create the asset tree, separating them into basic (information and services) [145].
 - **Supporting** (such as hardware, software, communications): The system automatically recognizes dependencies, transferring security requirements from the basics to the supporting components [146].

The user rates the importance of each asset (scale 0-10), thereby determining the level of protection required [147].



- **Pre-Installed Libraries:** One of the major advantages of PILAR Basic is that it frees the user from the need to create lists of threats or measures from scratch. The app comes with built-in libraries that are activated through the security profile option:
 - **Security standards:** The tool provides ready-made sets of security measures based on international standards (such as ISO 27002) or security levels (e.g. Low, Medium, High). The user selects the desired profile and the application automatically "fills" the requirements for each asset [148].

- **Threat Lists:** Based on the type of asset, the system automatically suggests the relevant threats from the MAGERIT standard library, as well as the typical probability of their occurrence [149].

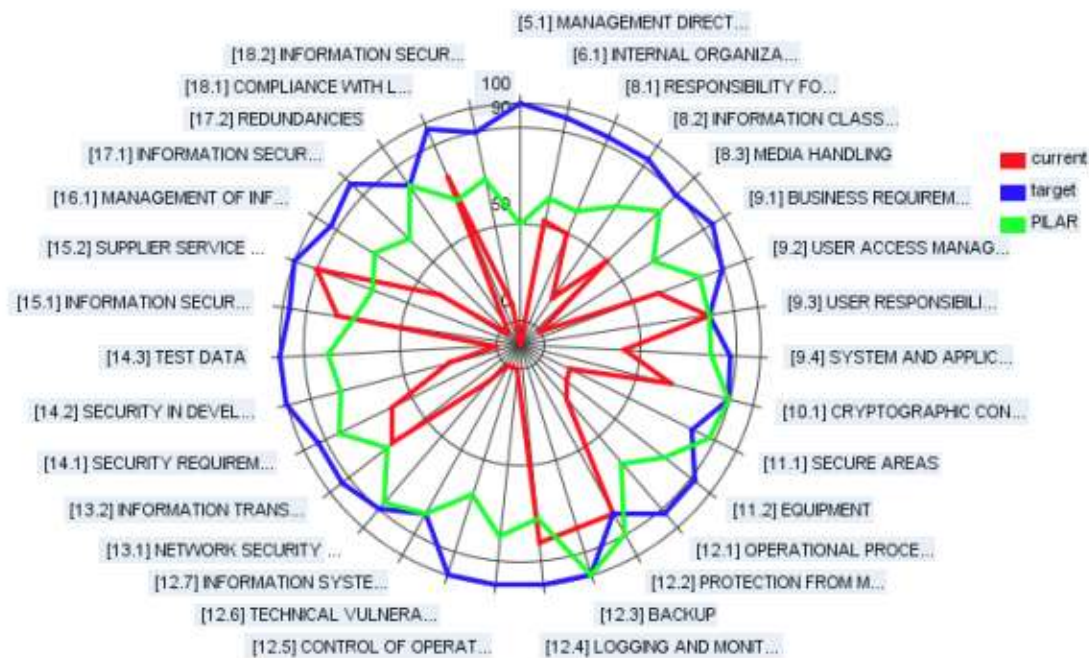


The screenshot shows the 'demo] evl > valuation' window in the PILAR Basic application. The table displays various controls with their current and target risk levels (L2, L4, L3) and the resulting PILAR risk level. The controls are listed under the 'control' column, and the risk levels are shown in the 'current', 'target', and 'PILAR' columns. The table is filtered by 'level' 3, and the 'domains' button is visible at the bottom.

rec...	level	control	do...	ba...	co...	current	target	PILAR
		[27002:2022] Information security controls				L2	L4	L2-L3 (...)
3		✓ [5] Organizational controls /PR CR DC		...		L2	L4	L2-L3
3		✓ [5.1] Policies for information security /PR				L2	L4	L3 (L2)
3		✓ [5.2] Information security roles and responsibilities /PR				L2	L4	L3 (L2)
2		✓ [5.3] Segregation of duties /PR				L2	L4	L2 (L2-...)
3		✓ [5.4] Management responsibilities /PR				L2	L4	L3 (L2)
3		✓ [5.5] Contact with authorities /PR CR				L2	L4	L3 (L2)
3		✓ [5.6] Contact with special interest groups /PR CR				L2	L4	L3 (L2-...)
3		✓ [5.7] Threat intelligence /PR CR DC				L2	L4	L3
		✓ [5.8] Information security in project management /PR		n.a.				
3		✓ [5.9] Inventory of information and other associated assets /PR				L2	L4	L3 (L2-...)
3		✓ [5.10] Acceptable use of information and other associated assets /PR				L2	L4	L3 (L2)
2		✓ [5.11] Return of assets /PR				L2	L4	L2 (L3)
1		✓ [5.12] Classification of information /PR				L2	L4	L2
1		✓ [5.13] Labelling of information /PR				L2	L4	L2 (L2-...)
1		✓ [5.14] Information transfer /PR				L2	L4	L2 (L2-...)
3		✓ [5.15] Access control /PR				L2	L4	L3 (L2)

- **Calculation Mechanism:** The calculation of risk in PILAR Basic is dynamic and takes place in real time as the user enters data [150]. The mechanism works by comparing two situations, which are shown as distinct phases in the application:
 - **Current status:** Calculates risk based on measures already implemented in the organization.
 - **Objective:** Calculate the foreseeable risk if the proposed measures are implemented [151].

The result is visualized and directly indicates whether the risk exceeds the acceptable limit, taking into account the likelihood of the threat and the impact on the asset [152].



- **Reports:** The final phase of functionality, as described in the application menu, is documentation production. PILAR Basic has a built-in report engine that outputs the results in editable format [153]. Available reports include:

1. Executive Summary.
2. Detailed Technical Report.
3. Statement of Applicability.
4. Risk Treatment Plan.

5.2.4.3 User Experience

The user experience in PILAR Basic is far from modern design standards (Modern UI). The interface does not have a modern aesthetic, but refers to older, classic software, with a strict and "industrial" look. The menu is simple in its structure, without graphic excesses, but it is not intuitive for a new user. Complex options are not immediately understandable without prior familiarity. Although the interface is not attractive, the workflow is specific. The tool becomes fully understandable and

functional, as long as the user devotes the necessary time for research and training on how it works. Finally, the fragmentation of the software into different versions (μ PILAR, Basic, RM, BCM) plays a decisive role in the experience. On the one hand, this can cause initial confusion, as research is required by the interested party to understand the differences and choose the right tool. On the other hand, once the logic of the PILAR family is understood, this variety works in favor of the user. It offers flexibility in both cost and functionality, allowing each organization to source exactly the version that meets its needs, without paying for unnecessary features.

5.3 Benchmarking and Conclusions

The table below presents the comparative overview of the four software tools (SimpleRisk, MONARC, Verinice, EAR/PILAR), based on the technical and functional criteria defined in the methodology of this study.

Comparison Criteria	SimpleRisk	MONARC	Verinice	EAR/PILAR (Basic)
Technical Identity and Licensing				
Licensing Model	The core core is open and free. What you pay: The additional Modules (functions) that snap onto the core.	All code and app are free. What you pay: Nothing. There is no commercial part of software.	The code is open, but the ready-made program (exe) is charged. What you pay: The ready-made application and updates.	The code is closed and proprietary. What you pay: The license to use it from the beginning to operate the program.
Free Distribution Range	Free (Core) The cost applies only to Extras (Price upon contact). Limitation of the free tool: Requires a corporate email to download.	Free There are no acquisition or subscription costs. Full access to all features without any restrictions.	~714 €/year The subscription costs €714.00 (year) or €1,285.20 (two years). Limitation of the free tool: It does not allow saving reports and exporting.	Varies (€100 - €8,000)/year Prices depending on the version and type (Rent/Purchase). Limitation of the free tool (Trial): 30-day trial with no print/export capability.

Architecture and Requirements	Web-based Installation on Linux Server. Requirements: Low (2 vCPU, 2GB RAM). Access via Browser.	Web-based Install on Docker/VM. Requirements: Medium (4GB RAM for VM). Access via Browser.	Desktop Dependent application (Eclipse RCP). Requirements: Runs locally on all OS. Medium (4GB RAM).	Desktop Standalone application. Requirements: Very low. It only requires Java Runtime (JRE 8+).
Risk Management Functionality				
Asset Management	Lists and IP Scanning Flat listing. That is, it does not have a tree structure with envelopes and subfolders. Key: Automation through scanning to quickly find devices (speed).	Inheritance Tree Dynamic tree structure. There is a separation of the assets that are at risk and are not at risk and we focus on the first case. Key: Value and impact are automatically "inherited" from the services to the equipment.	Inventory Tree Hierarchical mapping of infrastructure. Key: Focus on bulk import from IT inventory tools.	Dependency Structure (MAGERIT) Strict Essential/Support separation. Key: Automatic correlation of dependencies between layers. Calculating the impact.
Pre-installed Libraries	Includes mappings for compliance with: NIST, ISO, PCI DSS, HIPAA	Library of objects and threats based on: ISO 27005 and CASES	Full Directory Integration: BSI IT-Grundschutz, ISO 27001, VDA	Ready-made packages of measures and threats based on: MAGERIT and ISO 27002
Calculation Mechanism	Customizable It calculates intrinsic (without measures) and residual risk (after measures). Function: It allows for the creation of custom math formulas to calculate the score.	Semi-quantitative It uses Impact x Probability tables. Function: The impact is automatically "inherited" from the operational process to the technical equipment, saving time.	Standardized (ISO 27005) It performs rigorous analysis based on ISO 27005. Function: Automatically Associates: Threat→Vulnerability→Measure→Risk, as defined by ISO.	Dynamic (Real-time) It calculates in real time the current and targeted situation. Function: The risk is adjusted in real time according to the rate of effectiveness of the measures.
References	It provides supervisory Dashboards and trend charts (Risk Trends) for	It automatically generates the Statement of Applicability, risk	The free version does not allow the production or export of any report.	The Trial does not allow you to print or export files.

	immediate visual information. The ability to fully export detailed reports usually requires the purchase of additional modules.	tables, and response plan. It offers free export of all elements to PDF and Excel format files.	The full commercial version provides all reports in editable formats (Word, Excel, PDF).	The full commercial version provides specialized reports (Executive and Technical Reports) for each level of management.
User Experience	Modern Environment It has modern graphics and dashboards. Tutorial: The navigation is pleasant, although the menus are dense with information initially.	Intuitive Navigation Organization with drag-and-drop functions and tree structure. Tutorial: Smooth, as the environment guides the user through the process.	Complex Environment Multi-window and tabbed environment (legacy technology). Tutorial: Steep (difficult). It requires a significant amount of getting used to it.	Simple and Strict Simple design without graphic elements with an industrial profile. Tutorial: It requires training in methodology to understand the workflow.

Conclusions

The comparative overview of the four software tools (SimpleRisk, MONARC, Verinice, EAR/PILAR) reveals a significant heterogeneity in the market for GRC systems. Although all tools serve the common purpose of risk management, they approach the problem from different starting points, creating clear dividing lines in terms of usage philosophy, depth of analysis and economic model.

In terms of licensing and cost, MONARC stands out as the only solution that offers its full potential without any cost, making it ideal for organizations on a tight budget. In contrast, SimpleRisk and Verinice follow hybrid models, where full functionality requires payment, while EAR/PILAR remains a purely commercial solution with a high cost of acquisition and specialized capabilities.

As far as the methodological approach is concerned, there is an escalation from simplicity to rigor:

- SimpleRisk focuses on speed and supervision, using flat lists and scanning automations, but sacrificing structural detail.
- MONARC introduces the innovation of "inheritance," offering a balanced approach that reduces workload through intelligent impact transfer from services to equipment.
- Verinice works as a compliance tool, based on strict standards (ISO/BSI) and inventory trees, ideal for audits but cumbersome to use.

- EAR/PILAR offers the greatest analytical depth with the MAGERIT methodology, dynamically calculating risk and dependencies, but mainly aimed at specialized analysts.

Finally, the user experience confirms the gap between modern web applications and traditional office applications. Web-based solutions (SimpleRisk, MONARC) offer modern, collaborative environments with easy learning. On the other hand, Desktop applications (Verinice, PILAR) are characterized by "industrial" aesthetics and high complexity, requiring significant familiarization time. SBy synopsis:

- For organizations looking for an integrated, free and collaborative solution, MONARC is the optimal choice.
- For those who prioritize visualization and ease of use, SimpleRisk offers the best oversight.
- For requirements of strict compliance with European standards (BSI/ISO), Verinice is a one-way street.
- For environments that require mathematical precision and dynamic analysis of complex dependencies, EAR/PILAR is the most technically powerful tool.

6. Bibliography

ISO 27005

[1]: "ISO (the International Organization for Standardization) and IEC (the International Electrotechnical Commission) form the specialized system for worldwide standardization.", p. 5

[2]: "National bodies that are members of ISO or IEC participate in the development of International Standards through technical committees established by the respective organization to deal with particular fields of technical activity.", p. 5

[3]: "This document was prepared by Joint Technical Committee ISO/IEC JTC 1, Information technology, Subcommittee SC 27, Information security, cybersecurity and privacy protection.", p. 5

[4]: "This fourth edition cancels and replaces the third edition (ISO/IEC 27005:2018), which has been technically revised.", p. 5

- [5]: Activities | ELOT - Hellenic Organization for Standardization.
<https://elot.gr/drastiriotites-elot/>.
- [6]: "Fourth edition 2022-10", p. 1
- [7]: "all guidance text has been aligned with ISO/IEC 27001:2022, and ISO 31000:2018;", p. 5
- [8]: "the terminology has been aligned with the terminology in ISO 31000:2018;", p. 5
- [9]: "the structure of the clauses has been adjusted to the layout of ISO/IEC 27001:2022;", p. 5
- [10]: "For an explanation of the voluntary nature of standards... see www.iso.org/iso/foreword.html.", p. 5
- [11]: "ISO (the International Organization for Standardization) and IEC (the International Electrotechnical Commission) form the specialized system for worldwide standardization."
- [12]: "This document provides guidance to assist organizations to: fulfil the requirements of ISO/IEC 27001 concerning actions to address information security risks; perform information security risk management activities...", p. 7
- [13]: "ISO (the International Organization for Standardization) and IEC (the International Electrotechnical Commission) form the specialized system for worldwide standardization.", p. 5
- [14]: "National bodies that are members of ISO or IEC participate in the development of International Standards through technical committees...", p. 5
- [15]: "This document is applicable to all organizations, regardless of type, size or sector.", p. 7
- [16]: ELOT EN ISO/IEC 27005 | ELOT <https://eshop.elot.gr/product/106819>
- [17]: "Top management is accountable for managing risks and should lead and drive risk assessments, including: ensuring that the necessary resources are allocated to managing risk", p. 33
- [18]: "When making plans for routine risk assessments, organizations should take account of any calendar that applies to their general business processes and associated budget cycles. ... Funds are then granted (diminished or denied) later.", p. 31
- [19]: "Proactive methods... can be used to identify vulnerabilities depending on... available resources (e.g. allocated funds, available technology, persons with the expertise to conduct the test).", p. 57

- [20]: "This monitoring and review activity should address (but not be limited to): ... total cost of ownership; necessary resources.", p. 39
- [21]: "This document is applicable to all organizations, regardless of type, size or sector. ... An organization... can also be a subset of a legal entity (e.g. the IT department of a company).", p. 7, 9
- [22]: "risk: effect of uncertainty on objectives... In the context of information security management systems, information security risks can be expressed as effect of uncertainty on information security objectives.", p. 2
- [23]: "The risk assessment should help the organization make decisions about the management of the risks that affect the achievement of its objectives.", p. 10
- [24]: "The assets can be divided into two categories: primary/business assets... supporting assets (components of the information system on which one or several business assets are based).", p. 47
- [25]: "This document provides guidance on: implementation of the information security risk requirements specified in ISO/IEC 27001... essential references within the standards developed by ISO/IEC JTC 1/SC 27", p. 6
- [26]: "This document provides guidance to assist organizations to: fulfil the requirements of ISO/IEC 27001 concerning actions to address information security risks", p. 7
- [27]: "This document contains detailed guidance on risk management and supplements the guidance in ISO/IEC 27003.", p. 6
- [28]: "This document provides guidance on... implementation of risk management guidance in ISO 31000 in the context of information security.", p. 6
- [29]: "Normative references... ISO/IEC 27000, Information technology — Security techniques — Information security management systems — Overview and vocabulary", p. 7
- [30]: "As Figure 1 illustrates, the information security risk management process can be iterative for risk assessment and/or risk treatment activities.", p. 8
- [31]: "This process is based on the general risk management process defined in ISO 31000.", p. 7
- [32]: "strategic cycle, where business assets, risk sources and threats, target objectives or consequences to information security events are evolving from changes in the overall context of the organization.", p. 9

- [33]: "operational cycle, where the above-mentioned elements serves as input information or changed criteria that will affect a risk assessment or assessment where the scenarios should be reviewed and updated.", p. 9
- [34]: "The information security risk management process should be continually monitored, reviewed and improved as necessary.", p. 39
- [35]: "ISO/IEC 27001 does not mandate a particular approach... ensure that repeated information security risk assessments produce consistent, valid and comparable results.", p. 16
- [36]: "Nevertheless, there are two main approaches for assessment: an event-based approach and an asset-based approach.", p. 16
- [37]: "Event-based approach: identify strategic scenarios through a consideration of risk sources, and how they use or impact interested parties to reach those risk's desired objective.", p. 17
- [38]: "An event-based approach can establish high level or strategic scenarios without spending a considerable amount of time in identification of assets on a detailed level... Events and consequences can often be determined by a discovery of the concerns of top management", p. 17
- [39]: "Asset-based approach: identify operational scenarios, which are detailed in terms of assets, threats and vulnerabilities.", p. 17
- [40]: "With an asset-based approach, the underlying concept is that risks can be identified and assessed through an inspection of assets, threats and vulnerabilities. An asset is anything that has value to the organization and therefore requires protection.", p. 17
- [41]: "The asset-based approach can identify asset-specific threats and vulnerabilities and allows the organization to determine specific risk treatment on a detailed level.", p. 18
- [42]: "Identifying the contributory risk sources using an event-based assessment typically requires drilling down from the general level of the scenario to the detail level", p. 24
- [43]: "but an asset-based assessment typically searches upwards from the asset to the scenario, in order to provide visibility regarding how consequences accumulate.", p. 24
- [44]: "ISO/IEC 27001 does not mandate a particular approach to be used to fulfil the requirements in ISO/IEC 27001:2022, 6.1.2.", p. 16

- [45]: "Techniques for risk analysis based on consequences and likelihood can be: a) qualitative... b) quantitative... c) semiquantitative", p. 19
- [46]: "The categories and values used in Table A.2 and Table A.4 are only examples. The most appropriate value to assign to each level of likelihood depends on the risk profile and risk appetite of the organization.", p. 42
- [47]: "No single organization is likely to encounter the range of risk represented by the entirety of these example scales. The context of the organization... should be used to define realistic upper and lower limits", p. 45
- [48]: "The level of risk can be determined in many possible ways. It is commonly determined as a combination of the assessed likelihood and the assessed consequences for all relevant risk scenarios.", p. 22
- [49]: "Alternative calculations can include an asset value as well as likelihood and consequence.", p. 22
- [50]: "In addition, the calculation is not necessarily linear, e.g. it can be likelihood squared combined with consequence.", p. 22
- [51]: "In any case the level of risk should be determined using the criteria established as described in 6.4.3.4.", p. 22
- [52]: "Table A.10 gives examples of typical threats. The list can be used during the threat assessment process.", p. 53
- [53]: "Threats considered as risk sources can be deliberate, accidental or environmental (natural)... The list indicates for each threat type where D (deliberate), A (accidental), E (environmental) is relevant.", p. 53
- [54]: "Table A.11 gives examples for vulnerabilities in various security areas, including examples of threats that can exploit these vulnerabilities.", p. 55
- [55]: "The lists can provide help during the assessment of threats and vulnerabilities... In some cases, other threats can exploit these vulnerabilities as well.", p. 54
- [56]: "Context establishment means assembling the internal and external context for information security risk management", p. 8
- [57]: "ISO/IEC 27001 specifies requirements for an organization to establish and maintain information security risk criteria that include: a) the risk acceptance criteria; b) criteria for performing information security risk assessments.", p. 11
- [58]: "It means the chosen method should ensure the following properties of results: consistency... comparability... validity", p. 16

[59]: "This can involve... involvement of expertise in the relevant field, or other ways to collect the information required", p. 8-9

[60]: "Particularly where the qualitative approach is adopted, risk analysts should undergo training and periodic practice against an anchoring reference scale to maintain the calibration of their judgement.", p. 41

[61]: "Top management is accountable for managing risks... ensuring that the necessary resources are allocated to managing risk", p. 33

[62]: "Interviews with top management and those people in the organization who have a responsibility for a business process can assist in identifying not only the relevant events", p. 17

[63]: "To increase the reliability of estimating likelihood, organizations should consider using: a) team assessments rather than individual assessments", p. 21

[64]: "The risk communication and consultation activity should be performed continually.", p. 34

[65]: "When making plans for routine risk assessments, organizations should take account of... associated budget cycles... This monitoring and review activity should address... total cost of ownership", p. 31, 39

[66]: "ISO/IEC 27001 specifies requirements for organizations to retain documented information concerning the risk assessment process... and results", p. 35

[67]: "Documented information... should contain: a) a definition of the risk criteria... b) the identity of the risk owner(s)... Documented information about the information security risk treatment process should contain descriptions of... how risk treatment plans are produced", p. 35-36

NIST

[68]: "NIST Special Publication 800-39 is the flagship document... The purpose... is to provide guidance for an integrated, organization-wide program for managing information security risk," NIST SP 800-39, p. 3

[69]: "The purpose of Special Publication 800-30 is to provide guidance for conducting risk assessments... amplifying the guidance in Special Publication 800-39.", NIST SP 800-30, p. 2

- [70]: "Special Publication 800-30 is being revised to provide guidance on risk assessment as a supporting document to Special Publication 800-39.", NIST SP 800-39, p. 4
- [71]: "National Institute of Standards and Technology U.S. Department of Commerce," NIST SP 800-39, pp. 1 & NIST SP 800-30 Rev.1, p. 1
- [72]: "This publication has been developed by NIST to further its statutory responsibilities under the Federal Information Security Management Act (FISMA), Public Law (P.L.) 107-347.", NIST SP 800-39, p. 3 & NIST SP 800-30 Rev.1, p. 3
- [73]: "NIST is responsible for developing information security standards and guidelines, including minimum requirements for federal information systems...", NIST SP 800-39, p. 3 & NIST SP 800-30 Rev.1, p. 3
- [74]: "This publication was developed by the Joint Task Force Transformation Initiative Interagency Working Group with representatives from the Civil, Defense, and Intelligence Communities...", NIST SP 800-39, p. 5 & NIST SP 800-30 Rev.1, p. 5
- [75]: "March 2011", NIST SP 800-39, p. 1
- [76]: "Special Publication 800-39 supersedes the original Special Publication 800-30 as the source for guidance on risk management.", NIST SP 800-39, p. 4
- [77]: "September 2012", NIST SP 800-30 Rev.1, p. 1
- [78]: "Nothing in this publication should be taken to contradict the standards and guidelines made mandatory and binding on federal agencies by the Secretary of Commerce under statutory authority.", NIST SP 800-39, p. 3 & NIST SP 800-30 Rev.1, p. 3
- [79]: "This publication may be used by nongovernmental organizations on a voluntary basis...", NIST SP 800-39, pp. 3 & NIST SP 800-30 Rev.1, p. 3
- [80]: "... and is not subject to copyright in the United States. Attribution would, however, be appreciated by NIST.", NIST SP 800-39, p. 3 & NIST SP 800-30 Rev.1, p. 3
- [81]: "The guidelines in this publication are applicable to all federal information systems other than those systems designated as national security systems...", NIST SP 800-30 Rev.1, p. 2 & NIST SP 800-39, pp. 3
- [82]: "State, local, and tribal governments, as well as private sector organizations are encouraged to consider using these guidelines, as appropriate.", NIST SP 800-30 Rev.1, p. 2 & NIST SP 800-39, pp. 3

[83]: "The concepts and principles... are intended to be similar to and consistent with the processes and approaches described in International Organization for Standardization (ISO)... reduces the burden on organizations that must conform to ISO/IEC and NIST standards.", NIST SP 800-30 Rev.1, p. 3 & NIST SP 800-39, pp. 4

[84]: "This publication may be used by nongovernmental organizations on a voluntary basis and is not subject to copyright in the United States.", NIST SP 800-30 Rev.1, p. 3 & NIST SP 800-39, pp. 3

[85]: "Attribution would, however, be appreciated by NIST.", NIST SP 800-30 Rev.1, p. 3 & NIST SP 800-39, pp. 3

[86]: "All NIST publications are available at <http://csrc.nist.gov/publications>.", NIST SP 800-30 Rev.1, p. 3 & NIST SP 800-39, p. 3

[87]: "To integrate the risk management process throughout the organization, a three-tiered approach is employed that addresses risk at the: (i) organization level; (ii) mission/business process level; and (iii) information system level.", NIST SP 800-39, p. 9

[88]: "Tier 1 addresses risk from an organizational perspective... Tier 1 implements the first component of risk management (i.e., risk framing), providing the context for all risk management activities carried out by organizations.", NIST SP 800-39, p. 9

[89]: "Tier 2 addresses risk from a mission/business process perspective... Tier 2 risk management activities include... establishing an enterprise architecture... Tier 2 activities directly affect the activities carried out at Tier 3.", NIST SP 800-39, p. 10

[90]: "Tier 3 addresses risk from an information system perspective... Tier 3 risk management activities include: (i) categorizing organizational information systems; (ii) allocating security controls... and (iii) managing the selection, implementation, assessment, authorization, and ongoing monitoring...", NIST SP 800-39, p. 10

[91]: "The risk management process is carried out seamlessly across the three tiers with the overall objective of... effective inter-tier and intra-tier communication... and a feedback loop for continuous improvement", NIST SP 800-39, p. 9

[92]: "NIST Special Publication 800-39 is the flagship document in the series of information security standards and guidelines developed by NIST in response to FISMA.", NIST SP 800-39, p. 3

[93]: "Risk assessment is a key component of a holistic, organization-wide risk management process as defined in NIST Special Publication 800-39", NIST SP 800-30 Rev.1, p. 4

- [94]: "Special Publication 800-37, Guide for Applying the Risk Management Framework to Federal Information Systems...", NIST SP 800-39, p. 4
- [95]: "Special Publication 800-53, Recommended Security Controls for Federal Information Systems and Organizations," NIST SP 800-39, pp. 4
- [96]: "The concepts and principles... are intended to be similar to and consistent with the processes and approaches described in International Organization for Standardization (ISO)... reducing the burden on organizations", NIST SP 800-30 Rev.1, p. 3
- [97]: "Risk management is a comprehensive process that requires organizations to: (i) frame risk... (ii) assess risk; (iii) respond to risk... and (iv) monitor risk on an ongoing basis," NIST SP 800-39, p. 6
- [98]: "Risk management... ensuring that risk-based decision making is integrated... using effective organizational communications and a feedback loop for continuous improvement", NIST SP 800-39, p. 6
- [99]: "Risk assessment activities can be integrated with the steps in the Risk Management Framework (RMF), as defined in NIST Special Publication 800-37.", NIST SP 800-30 Rev.1, p. 20
- [100]: "risk assessments are conducted throughout the system development life cycle, from pre-system acquisition... through system acquisition... and on into sustainment", NIST SP 800-30 Rev.1, p. ix
- [101]: "Risk, and its contributing factors, can be assessed in a variety of ways, including quantitatively, qualitatively, or semi-quantitatively.", NIST SP 800-30 Rev.1, p. 14
- [102]: "Quantitative assessments typically employ a set of methods... based on the use of numbers... This type of assessment most effectively supports cost-benefit analyses... rigor... is significantly lessened when subjective determinations are buried", NIST SP 800-30 Rev.1, p. 14
- [103]: "Qualitative assessments typically employ a set of methods... based on nonnumerical categories or levels... supports communicating risk results to decision makers... range of values... is comparatively small, making the relative prioritization... difficult", NIST SP 800-30 Rev.1, p. 14
- [104]: "Semi-quantitative assessments typically employ a set of methods... that uses bins, scales, or representative numbers... This type of assessment can provide the benefits of quantitative and qualitative assessments... relative prioritization among results is better supported", NIST SP 800-30 Rev.1, p. 14

[105]: "A preferred approach (or situation-specific set of approaches) can be selected based on organizational culture and, in particular, attitudes toward the concepts of uncertainty and risk communication.", NIST SP 800-30 Rev.1, p. 14

[106]: "There are no specific requirements with regard to... formality, rigor... methodologies, tools... Organizations have maximum flexibility on how risk assessments are conducted", NIST SP 800-30 Rev.1, p. ix

[107]: "The templates are exemplary and can be tailored by organizations in accordance with specific organizational mission/business requirements.", NIST SP 800-30 Rev.1, p. 29

[108]: "The assessment scales in this appendix can be used as a starting point with appropriate tailoring to adjust for any organization-specific conditions.", NIST SP 800-30 Rev.1, p. I-1

[109]: "The use of the templates is not required in order to conduct risk assessments.", NIST SP 800-30 Rev.1, p. 29

[110]: "A single risk model... cannot meet the diverse needs... The expectation... is that each organization... will define a risk model appropriate to its view of risk", NIST SP 800-30 Rev.1, p. 16

[111]: "Risk is a measure... typically a function of: (i) the adverse impacts... and (ii) the likelihood of occurrence.", NIST SP 800-30 Rev.1, p. 6

[112]: "Qualitative assessments typically employ... nonnumerical categories or levels (e.g., very low, low, moderate, high, very high).", NIST SP 800-30 Rev.1, p. 14

[113]: "The bins (e.g., 0-15, 16-35, 36-70, 71-85, 86-100) or scales (e.g., 1-10) translate easily into qualitative terms... while also allowing relative comparisons", NIST SP 800-30 Rev.1, p. 14

[114]: "Table I-2: Assessment Scale - Level of Risk (Combination of Likelihood and Impact)... High (Likelihood) + Moderate (Impact) = High (Risk)", NIST SP 800-30 Rev.1, p. I-1

[115]: "This broad definition also allows risk to be represented as a single value or as a vector (i.e., multiple values), in which different types of impacts are assessed separately.", NIST SP 800-30 Rev.1, p. 12

[116]: "Uncertainty is inherent in the evaluation of risk... The degree of uncertainty... can be communicated in the form of the results", NIST SP 800-30 Rev.1, p. 13

[117]: "The taxonomy and assessment scales in this appendix can be used by organizations as a starting point with appropriate tailoring to adjust for any organization-specific conditions.", NIST SP 800-30 Rev.1, p. D-1

[118]: "In general, types of threat sources include: (i) hostile cyber or physical attacks; (ii) human errors... (iii) structural failures... and (iv) natural and man-made disasters", NIST SP 800-30 Rev.1, p. 8

[119]: "Appendix D... (ii) an exemplary taxonomy of threat sources... (iii) an exemplary set of tailorable assessment scales for assessing those risk factors", NIST SP 800-30 Rev.1, p. D-1

[120]: "Appendix E... (ii) representative examples of adversarial threat events expressed as tactics, techniques, and procedures (TTPs) and non-adversarial threat events", NIST SP 800-30 Rev.1, p. E-1

[121]: "Predisposing conditions... contribute to (i.e., increases or decreases) the likelihood that one or more threat events... result in adverse impacts... (e.g., the location of a facility in a hurricane- or flood-prone region... or a stand-alone information system)", NIST SP 800-30 Rev.1, p. 10

[122]: "Organizations can eliminate certain threat events from further consideration if no adversary with the necessary capability has been identified. Organizations can also modify the threat events provided," NIST SP 800-30 Rev.1, p. E-1

[123]: "Managing risk is a complex, multifaceted activity that requires the involvement of the entire organization from senior leaders/executives... to individuals on the front lines", NIST SP 800-39, pp. 6

[124]: "The risk executive (function) requires a mix of skills, expertise, and perspectives... supported by an expert staff", NIST SP 800-39, p. 13

[125]: "Individuals with information security/risk assessment and monitoring responsibilities (e.g., system evaluators, penetration testers, security control assessors...)", NIST SP 800-30 Rev.1, p. 3

[126]: "The risk management process is carried out seamlessly across the three tiers... effective inter-tier and intra-tier communication", NIST SP 800-39, p. 9

[127]: "Where automated monitoring is feasible, it should be employed because it is generally faster, more efficient, and more cost-effective than manual monitoring.", NIST SP 800-39, p. 47

[128]: "This publication is intended to serve a diverse group... Individuals with oversight responsibilities... (e.g., heads of agencies, chief executive officers...)", NIST SP 800-39, p. 3

[129]: "The risk executive (function) serves as the common risk management resource for senior leaders/executives... authorizing officials... security control assessors", NIST SP 800-39, p. 12

[130]: "Appendix K provides the essential elements of information that organizations can use to communicate the results of risk assessments... (i) an executive summary; (ii) the main body... and (iii) supporting appendices.", NIST SP 800-30 Rev.1, p. K-1

[131]: "The fourth component of risk management addresses how organizations monitor risk over time... verify that planned risk response measures are implemented... determine the ongoing effectiveness", NIST SP 800-39, p. 7

[132]: "Where automated monitoring is feasible, it should be employed because it is generally faster, more efficient, and more cost-effective than manual monitoring.", NIST SP 800-39, p. 47

Tools

[133]: SimpleRisk Pricing & Licensing Model | SimpleRisk

<https://www.simplerisk.com/pricing>

[134]: Manual Installation Download Form | SimpleRisk

<https://www.simplerisk.com/download/manual>

[135]: Try SimpleRisk: Demo, Trial & Sandbox Options | SimpleRisk

<https://www.simplerisk.com/try>

[136]: What are the requirements for me to run SimpleRisk? | SimpleRisk Support

<https://simplerisk.freshdesk.com/support/solutions/articles/6000156747-what-are-the-requirements-for-me-to-run-simplerisk->

[137]: SimpleRisk Sandbox Environment (Screenshots: Self Assessments Menu) | SimpleRisk Demo <https://demo.simplerisk.com>

[138]: Details about the ISMS-Tool verinice.

<https://verinice.com/en/products/verinice/about-verinice>

[139]: Software. <https://shop.verinice.com/en/Software/>

[140]: verinice Standalone for information security management.

<https://verinice.com/en/products/verinice/verinice-standalone>

- [141]: verinice. (2020) verinice Demo: Establishing an ISMS according to ISO 27001. https://www.youtube.com/watch?v=vB-xLN_vZnY
- [142] EAR - Environment for the Analysis of Risk. <https://www.pilar-tools.com/en/>
- [143] CCN-CERT, "PILAR - What is PILAR?". <https://pilar.ccn-cert.cni.es/en/pilar-solution/what-is-pilar>
- [144] PILAR Basic - User's Manual (2025), Chapter I: Introduction
- [145] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.1. Essential assets)
- [146] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.2. Support assets / II.3. Automation)
- [147] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.1.2. Rating)
- [148] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.4. Security profiles)
- [149] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.3. Automation) & Chapter IV: Advanced user (IV.1. Threats)
- [150] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.3. Automation)
- [151] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.4.3. Rating)
- [152] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.4.4 Traffic light)
- [153] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.5. Reporting)
- [154] MONARC Project, "Documentation and Project Identity". <https://www.monarc.lu/documentation/>
- [155] MONARC Project, "Quick Start Guide». <https://www.monarc.lu/documentation/quick-start/>
- [156] MONARC Project, "Technical Guide (Architecture & Requirements)". <https://www.monarc.lu/documentation/technical-guide/>
- [157] MONARC Documentation - User Guide, "Risk Analysis: Asset Definition & Tree Structure". <https://www.monarc.lu/documentation/user-guide/>
- [158] MONARC Documentation - Method Guide, "Libraries & Objects Management". <https://www.monarc.lu/documentation/method-guide/>
- [159] MONARC Documentation - Method Guide, "Risk Calculation & Assessment Scale". <https://www.monarc.lu/documentation/method-guide/>
- [160] MONARC Documentation - User Guide, "Reporting & Exports (SoA, Risk Treatment)". <https://www.monarc.lu/documentation/user-guide/>

- [161] MONARC Documentation - User Guide, "Dashboard & Interface Overview".
<https://www.monarc.lu/documentation/user-guide/>
- [162] MONARC Documentation - Method Guide, "Context Modelling & Inheritance".
<https://www.monarc.lu/documentation/method-guide/>
- [163] MONARC Project, "Features & Usability (Optimised Method)".
<https://www.monarc.lu/product/>